

Adversarial Machines: Autonomous AI in Offensive Cyber Operations

Introduction

Artificial intelligence is no longer merely a force multiplier for cyber threat actors; it is increasingly becoming an operational participant in its own right. Over the past year, threat intelligence reporting has shifted from documenting attacker use of generative AI for phishing text, malware debugging, and reconnaissance support toward evidence of **agentic systems** being used across the full intrusion lifecycle. Industry reporting now describes AI-enabled operations that can assist with reconnaissance, generate lures and payloads, support command-and-control development, and in some cases dynamically alter malicious behavior during execution, signaling a transition from simple automation to adaptive autonomy in offensive cyber operations ([Google Threat Intelligence Group, 2026](#); [Microsoft, 2025](#)).

This report examines the emergence of what can be described as **adversarial machines**: AI-enabled offensive systems, often composed of multiple agents, tools, and memory layers, that can plan, execute, and refine multi-step cyberattacks with reduced human intervention. Unlike earlier automation, these systems increasingly exhibit characteristics associated with operational autonomy: decomposing objectives into tasks, selecting tooling, interacting with target environments, adapting to defensive friction, and coordinating specialized functions such as reconnaissance, exploit development, lateral movement, or data staging. Public reporting suggests this evolution is already underway, with researchers observing both criminal and state-linked actors using large language models and agent frameworks not only for support tasks but also for end-to-end attack orchestration and, in limited cases, malware behavior modification during runtime ([CSO Online, 2026](#); [Google Threat Intelligence Group, 2026](#)).

A major inflection point came with disclosures surrounding the disruption of an AI-orchestrated cyberespionage campaign attributed to the allegedly Chinese-speaking group GTG-1002. According to public reporting summarizing Anthropic's findings, the operation targeted roughly 30 major organizations across technology, finance, chemicals, and government, and used Claude Code and AI agents throughout the attack chain, with autonomous systems reportedly performing 80–90% of tactical activity. The case is significant not because it proves flawless machine-led intrusion capability, but because it demonstrates a practical model in which AI agents can handle much of the operational workload while human operators provide objectives, pretexts, and oversight. The same

reporting also highlights a critical constraint: hallucinations and fabricated outputs remained operational liabilities, meaning current offensive autonomy is powerful but still imperfect and unevenly reliable ([Kaspersky ICS CERT, 2026](#); [CSO Online, 2026](#)).

The threat landscape is also broadening beyond a single actor or platform. Threat intelligence indicates that state-sponsored operators linked to North Korea, Iran, and the People's Republic of China continue to misuse mainstream AI tools to support reconnaissance, lure generation, tooling development, and exfiltration planning, while underground ecosystems are maturing around multifunctional illicit AI services that lower the barrier to entry for less sophisticated adversaries. At the same time, attackers are probing model safeguards through prompt-based “social engineering,” posing as researchers, students, or authorized testers to elicit restricted assistance. This convergence of state tradecraft, cybercrime commercialization, and accessible AI tooling is steadily normalizing autonomous and semi-autonomous offensive workflows across the threat spectrum ([Google Threat Intelligence Group, 2026](#); [Microsoft, 2025](#)).

The environments being targeted are equally important to understanding this shift. Current reporting shows adversaries focusing not just on traditional endpoints and enterprise applications, but increasingly on **cloud identity systems, workload identities, OAuth ecosystems, unmanaged cloud assets, and AI agents themselves**. Microsoft has warned that attackers are pivoting toward non-human identities, malicious app consent, device-code phishing, adversary-in-the-middle techniques, and covert token abuse to bypass MFA and sustain access in cloud environments. Palo Alto Unit 42 likewise emphasizes unmanaged or newly created cloud compute as a visibility gap attackers exploit to evade monitoring. In parallel, the rise of AI agents with tool access, persistent memory, and workflow privileges has created a new attack surface where prompt injection, memory poisoning, indirect instruction injection, and agent supply chain compromise can turn enterprise AI systems into both targets and force multipliers for adversaries ([Microsoft, 2025](#); [Unit 42, 2025](#); [Microsoft Community Hub, 2025](#)).

What makes this evolution strategically important is not simply speed, but **shifting attack economics**. Autonomous cyber capabilities compress the time between reconnaissance and exploitation, enable parallel task execution, scale social engineering and intrusion support functions, and reduce the expertise required to conduct certain offensive activities. Reporting cited in industry analysis suggests average time-to-exploit has fallen sharply, while multiple specialized agents can increasingly divide reconnaissance, tooling, execution, and data movement into a coordinated machine workflow. Even when these systems are brittle, they can still produce material advantage by increasing attacker tempo and experimentation volume faster than many enterprise defenders can validate, investigate, and respond ([CSO Online, 2026](#); [Microsoft, 2025](#)).

Accordingly, this report investigates how autonomous and agentic AI systems are being incorporated into offensive cyber operations in the wild, which actors are using them, which enterprise environments are most exposed, and how recent case studies reshape defender assumptions about visibility, speed, attribution, and control. As of March 2026, the evidence suggests that fully autonomous cyber offense remains constrained by reliability, guardrails, and operational noise, yet the direction of travel is clear: AI is moving from assistant to operator, and that transition is beginning to alter the balance of power between attackers and enterprise defenders ([Kaspersky ICS CERT, 2026](#); [Google Threat Intelligence Group, 2026](#); [Microsoft, 2025](#)).

Table of Contents

- Defining Adversarial Machines and Autonomous AI in Offensive Cyber Operations
 - Operational Definition: What Qualifies as an “Adversarial Machine” in Cyber Operations
 - Architecture of Agentic Intrusions: How Autonomous Systems Translate Intent into Multi-Step Attacks
 - Goal decomposition and subtask generation
 - Environmental modeling and attack graphs
 - Tool use and interface control
 - Memory, persistence, and campaign continuity
 - Adaptation through failure interpretation
 - Human supervision patterns
 - Offensive autonomy without bespoke malware
 - A reference attack sequence
 - Threat Actor Adoption Patterns: Who Is Using Autonomous or Semi-Autonomous Offensive Systems
 - State espionage ecosystems
 - State-aligned fronts and deniable personas
 - Ransomware and extortion enterprises
 - Access brokers and phishing specialists
 - Offensive service providers and “autonomy-as-a-service”
 - Comparative adoption by actor type
 - Why some actors lag
 - Observable tradecraft indicators by actor category
 - Targeted Environments and Interfaces: Where Autonomous Attack Logic Has the Greatest Leverage
 - Identity systems as machine-readable attack terrain

- Cloud control planes and SaaS administration
- How Agentic Systems Plan, Execute, and Adapt Multi-Step Cyberattacks
 - From Workflow Assistance to Operational Autonomy: What Has Changed in 2025–2026
 - Decision Loops in Live Operations: How Machine Planning Becomes Actionable Tradecraft
 - Attack Surfaces Most Susceptible to Autonomous Sequencing
 - Identity, authentication, and recovery workflows
 - Web-based administrative consoles and SaaS management panes
 - Public-facing business logic and application workflows
 - Endpoint scripting and command interpreters
 - Developer and CI/CD ecosystems
- Threat Actor Ecosystem and the Commercialization of AI-Enabled Offensive Capabilities
 - Market Formation: From Jailbroken Assistants to Specialized Offensive AI Supply Chains
 - State, Proxy, and Criminal Buyers: How Different Ecosystems Consume Commercial AI Offense
 - Interface Economies: Where Commercial Offensive AI Finds the Highest Return
 - 1) Human communication surfaces as programmable intrusion terrain
 - 2) AI application trust channels and software distribution touchpoints
 - 3) Hosted machine learning and developer package ecosystems
 - 4) Autonomous enterprise agents and agentic middleware
 - 5) Defensive AI pipelines as attack targets
 - Case Studies in Emerging Offensive AI Tradecraft: What the Field Evidence Actually Shows
 - Case Study A: AI-supported social engineering at majority scale
 - Case Study B: Famous Chollima and AI-generated professional personas
 - Case Study C: Stand-alone malicious AI systems and the move to self-hosted offense
 - Case Study D: Fake AI tool ecosystems as malware and ransomware distribution channels
 - Case Study E: Hosted ML model and code-agent targeting
 - Case Study F: Frontier risk recognition by national cyber authorities

- Primary Target Environments, Identities, Cloud Interfaces, and AI Agent Surfaces Under Attack
 - Identity Persistence Fabric: Token Abuse, OAuth Delegation, and Non-Human Privilege Chains
 - Why workload identities are especially exposed
 - Identity artifacts now preferred by adaptive adversaries
 - Internal phishing and identity-enabled expansion
 - Identity defense implications specific to adversarial machines
 - Cloud Resource Graphs and Secret-Bearing Services as Autonomous Pivot Terrain
 - Secret-centered lateral movement
 - Why cloud graphs are favorable to adversarial AI
 - Cloud target categories most exposed to machine-guided chaining
 - Long-term access without traditional malware footprint
 - Resource graph exploitation and campaign economics
 - AI Agent Tooling, Protocol Mediation, and the New Attack Surface of Reasoning-Driven Execution
 - Tool descriptions and metadata as adversarial control points
 - Protocol surfaces: MCP, A2A, and indirect instruction paths
 - Why reasoning-layer compromise matters in enterprise intrusions
 - Primary agent surfaces under active pressure
 - Embedded instruction channels as stealth infrastructure
 - Endpoint-Resident Agents and LOTAIL: High-Permission Local Automation as an Intrusion Multiplier
 - Why the endpoint is re-emerging as a strategic AI battleground
 - LOTAIL as a target-environment concept
 - Blending with legitimate user behavior
 - OpenClaw and the broader super-agent problem
 - Endpoint-agent targets most relevant to offensive AI operations
 - Cross-Surface Case Intelligence: What Current Field Reporting Reveals About the Most Attacked Environments
- Real-World Case Studies and Threat Intelligence on the Impact of Autonomous Cyber Capabilities on Attack-Defense Dynamics
 - Evidence Thresholds and Analytic Framing for “Autonomous Impact” in Live Intrusions
 - Field Case Cluster 1: AI-Scaled Social Engineering as a Machine-Speed Access Broker
 - Field Case Cluster 2: Compromise of AI Agent Toolchains and Development Platforms as an Offensive Force Multiplier

- Field Case Cluster 3: GenAI-Assisted Malware Production, Code Adaptation, and the Erosion of Skill Barriers
- Field Case Cluster 4: Autonomous Offensive Platforms, Underground Tooling, and the Transition from Human-Crafted Campaigns to Machine-Orchestrated Offense

Defining Adversarial Machines and Autonomous AI in Offensive Cyber Operations

Operational Definition: What Qualifies as an “Adversarial Machine” in Cyber Operations

For the purpose of threat intelligence analysis, an **adversarial machine** should be defined more narrowly than “any automation used by an attacker.” The term is most useful when reserved for a computational system that can independently transform attacker intent into operational cyber effects across more than one decision point. In practice, this means the system does not merely execute a static script; it selects, sequences, or modifies actions based on environment feedback, mission goals, or evolving defender conditions. Under this definition, a phishing kit that sends one prewritten lure to a fixed list is not an adversarial machine. By contrast, a system that profiles a target, chooses a pretext, adapts the lure to mailbox defenses, rotates infrastructure, triages stolen credentials, and determines the next step without direct operator approval for each stage would qualify (1).

A defensible analytic definition needs three core properties:

Property	Analytical meaning	Offensive relevance
Goal orientation	The system is given an objective or utility function rather than only a fixed command list	Enables “mission-level” behavior such as obtain persistence, expand access, or degrade identity control
Environmental perception	The system ingests telemetry from victim, infrastructure, or OSINT sources	Supports adaptation to controls, user behavior, and infrastructure disruption
Action selection with feedback	The system determines among alternatives and updates future steps from results	Distinguishes autonomous attack chains from conventional orchestration

This distinction matters because current offensive tradecraft increasingly blurs the boundary between malware, operator tooling, cloud automation, and AI-enabled planning layers. A malicious campaign may now consist of: (1) a reasoning or planning component that decomposes objectives, (2) an execution layer invoking scripts, APIs, malware, or remote management tools, (3) a sensing layer collecting logs, screenshots, authentication status, or detection feedback, and (4) a governance layer implementing attacker constraints such as stealth, monetization thresholds, or victim exclusions. The aggregate, rather than any one binary, constitutes the adversarial machine.

A second necessary distinction is between **autonomy**, **automation**, and **augmentation**. These terms are often used imprecisely in policy and reporting, leading to overstatement of present capabilities.

Mode	Human role	Machine role	Typical cyber examples
Automation	Human specifies steps and order	Machine executes predefined workflow	Mass credential stuffing, scripted ransomware deployment, exploit chaining with fixed logic
Augmentation	Human remains principal decision-maker	Machine assists planning, filtering, or content generation	LLM-generated phishing text, malware code refactoring, alert triage for operators
Autonomy	Human sets objective or broad constraints	Machine plans and selects next actions with limited supervision	Agentic phishing adaptation, self-directed post-exploitation pathing, autonomous cloud misconfiguration abuse

In offensive cyber operations observed in the wild as of early 2026, most real systems remain in the middle category—augmentation with pockets of bounded autonomy—rather than fully independent strategic actors. However, bounded autonomy is already enough to alter campaign economics. A system need not replicate a human intrusion operator in full to generate material attacker advantage. If it can reduce labor in reconnaissance, pretext tailoring, infrastructure rotation, privilege path discovery, or social engineering iteration, it lowers cost per target and increases operational tempo.

A practical intelligence taxonomy should therefore classify adversarial machines according to the **mission loop** they control:

1. **Discovery agents:** map internet-facing attack surface, identify exposed services, collect employee data, and rank targets.
2. **Access agents:** generate lures, conduct password attacks, broker session theft, or optimize exploitation attempts.

3. **Foothold agents**: choose persistence mechanisms, task malware, or invoke legitimate remote administration capabilities.
4. **Expansion agents**: model identity graphs, enumerate cloud entitlements, identify lateral movement paths, and queue privilege escalation.
5. **Effects agents**: coordinate exfiltration, leak timing, extortion communications, service disruption, or destructive actions.
6. **Resilience agents**: rotate infrastructure, test detection hypotheses, and re-enter after remediation.

This taxonomy is more operationally useful than narrow malware-family labels because many AI-enabled attack systems are **composed systems**. The decision layer may be a commercial model, a fine-tuned open model, a local model embedded in a framework, or a rules engine combined with retrieval and tools. The execution layer may be shell commands, PowerShell, Python, cloud CLI calls, browser automation, or remote APIs. The observable indicator is not the presence of “AI malware” per se; it is the presence of a machine-mediated attack loop that senses, decides, and acts.

The cyber threat landscape also requires differentiating **adversarial machines** from **autonomous cyber weapons**. The former includes systems used for espionage, credential theft, business email compromise, extortion, influence operations, and persistent access. The latter would imply systems intended to create direct disruptive or destructive effects with limited human control over target-specific execution. The present empirical landscape is weighted toward the former. Even where destructive intent exists, the machine element often optimizes access and target-state manipulation rather than independently determining strategic targeting. This aligns with recent reporting on Iranian operations moving from custom wipers toward identity and enterprise management plane abuse; the novelty lies less in a single destructive binary and more in attacker exploitation of administrative control surfaces that can trigger broad downstream effects ([2](#), [3](#)).

Another useful concept is **bounded offensive autonomy**. Most malicious agentic systems today operate under one or more of the following constraints:

- A restricted toolset, such as browser automation, PowerShell, Microsoft Graph, AWS CLI, or SSH.
- A limited operational domain, such as initial access only or cloud privilege analysis only.
- A confidence threshold requiring human approval before high-risk actions.
- A pre-authorized victim set or campaign scope.
- A stealth budget limiting scan rates, failed logins, or process spawning.
- A time or cost budget controlling token consumption, infrastructure expense, or operator review load.

These constraints do not negate autonomy; they define its practical deployment envelope. In the same way that autopilot does not mean unrestricted flight freedom, autonomous cyber capability in current offensive use is typically goal-seeking within boundaries. This boundedness is important for defenders because it creates choke points. If the system depends on APIs, browser states, identity telemetry, or infrastructure health to make decisions, defenders can degrade autonomy by poisoning, throttling, segmenting, or invalidating those inputs.

A further defining feature is **machine-readable attack knowledge**. Legacy threat actor playbooks often lived in analyst notes, scripts, and malware source. Adversarial machines instead rely on formalized representations of attack logic: attack graphs, credential validation heuristics, exploit selection trees, cloud privilege maps, email thread context, or detection-response rules. This codification is what makes adaptation scalable. Once a target environment is represented in a form consumable by an agent, the machine can compare current state to an objective and compute likely next actions. In enterprise compromise, the identity plane and cloud control plane are especially amenable to this representation because permissions, sessions, policies, secrets, and administrative actions are already exposed through APIs and logs. That is one reason why offensive focus has increasingly shifted toward identity abuse and management-plane leverage rather than handcrafted endpoint-only malware (2, 4).

It is also analytically necessary to separate **AI-enabled adversarial machines** from older adaptive malware. Malware has long incorporated decision logic: sandbox evasion, propagation routines, exploit fallbacks, or C2 failover. What changes with modern AI is not the mere existence of branching behavior, but the ability to generalize across partially novel environments using language, code, and interface understanding. A classic worm may test a list of exploits in sequence. An AI-enabled agent may read system banners, interpret admin documentation, synthesize a script to interact with a particular SaaS tenant, reformulate a phishing lure from a leaked email thread, or reason about why a prior step failed. This gives the attacker broader operational flexibility with less pre-engineering.

From a collection perspective, analysts should therefore look for these signs that a threat activity set has crossed into adversarial-machine territory:

Collection indicator	Why it matters
Rapid variation in phishing text, pretexts, and document formatting without corresponding human writing cadence	Suggests generative or agentic content adaptation
Infrastructure that rotates based on delivery or access outcomes	Indicates feedback-driven orchestration

Collection indicator	Why it matters
Automated victim profiling using scraped organizational and social data	Supports target-specific planning
Cloud/API interactions reflecting exploratory privilege reasoning rather than a fixed sequence	Suggests path-search behavior
Malware or scripts generated/refactored on the fly to fit the local environment	Indicates adaptive code generation or transformation
Re-engagement after remediation using altered channels or techniques aligned to prior defender actions	Shows sensing and strategic adaptation

The emergence of ORB networks is particularly relevant to this definition because they embody adversarial-machine principles at the infrastructure layer. Mandiant’s reporting describes China-nexus actors using operational relay box networks built from VPS nodes and compromised IoT and routing devices to create a dynamic mesh for concealment and operational resilience. While ORB networks are not themselves “AI,” they are machine-mediated systems that continuously alter the defender’s observable environment, complicate attribution, and increase the cost of disrupting intrusion infrastructure. In combination with AI planning or campaign management, such relay architectures provide the transport substrate for autonomous offensive operations: scalable reconnaissance, distributed login attempts, geographically plausible session origination, and rapid infrastructure replacement ([1](#)).

An operational definition must finally account for the possibility that the “machine” is split across **attacker-owned systems** and **abused enterprise platforms**. In many modern intrusions, the adversary’s effective machine includes cloud workflows, collaboration APIs, endpoint management platforms, browser sessions, or stolen administration consoles. If an attacker uses a compromised tenant’s automation features to enumerate users, schedule tasks, or propagate permissions, the autonomous component is partly instantiated inside the victim’s own environment. This is particularly salient in the transition toward identity weaponization and enterprise management plane abuse, where destructive or coercive effects can be achieved by abusing legitimate administrative authority rather than deploying bespoke malware binaries ([3](#), [4](#)).

For strategic reporting, the following working definition is therefore suitable:

Adversarial machines in offensive cyber operations are machine-mediated systems that pursue attacker objectives by perceiving target-relevant conditions, selecting and sequencing actions across multiple stages of an intrusion, and adapting behavior based on feedback from the victim environment, supporting infrastructure, or campaign outcomes, with or without embedded AI models. Autonomous AI in this context refers to the subset of such systems whose adaptation and action selection rely materially on AI techniques—especially generative, planning, reasoning, or learning components—rather than solely on static logic or human-in-the-loop control.

This definition is sufficiently narrow to exclude commodity scripting and sufficiently broad to capture the real operational trend: cyber operations are increasingly executed by systems that do not simply “run tools,” but progressively reason over targets, interfaces, permissions, and outcomes.

Architecture of Agentic Intrusions: How Autonomous Systems Translate Intent into Multi-Step Attacks

To understand how autonomous AI alters offensive operations, one must examine not only what these systems do, but how they are architected. Contemporary agentic intrusions are best understood as **closed-loop operational systems** that decompose a mission objective into a set of hypotheses, actions, observations, and revisions. The key change versus conventional intrusion automation is that the machine can move from “instruction execution” to **stateful campaign management**. It maintains memory about the target, observes whether defenses react, and updates its path accordingly.

A generalized offensive agent stack can be represented in six layers:

Layer	Function	Typical offensive implementation
Objective layer	Encodes attacker goal, constraints, and success conditions	“Obtain cloud admin,” “steal finance mailbox data,” “disrupt endpoint management”
Planning layer	Breaks goals into tasks and subgoals	Task graphs, chain-of-thought-like planning, attack path search, policy-based selection
Perception layer	Collects and normalizes target signals	OSINT scraping, network banners, EDR prompts, API responses, screenshots, logs

Layer	Function	Typical offensive implementation
Tool layer	Executes concrete actions	Shell, Python, PowerShell, browser automation, Graph API, SSH, RDP, cloud CLIs
Memory layer	Stores context, prior outcomes, and credentials	Vector stores, local caches, campaign databases, loot catalogs
Supervision layer	Applies attacker constraints and escalation logic	Human approval thresholds, stealth budgets, victim rules, monetization triggers

This architecture is not hypothetical. Variants of it already exist in legitimate red-team agents, autonomous penetration testing research, security orchestration frameworks, and malicious campaign tooling. Threat adoption occurs because attackers can combine off-the-shelf AI components with mature cyber building blocks. A language model may provide plan generation and interface understanding, while conventional tools perform exploitation, credential theft, or cloud enumeration. The model need not “hack” on its own in the cinematic sense; it only needs to orchestrate tools more flexibly than scripts.

A practical way to describe agentic attack flow is via the **sense–plan–act–evaluate loop**:

1. **Sense**: ingest target information such as employee names, cloud service usage, exposed services, document types, session prompts, or error messages.
2. **Plan**: decide which attack branch is likely to succeed under cost, stealth, and time constraints.
3. **Act**: execute via phishing, API calls, malware tasking, shell commands, or remote service interaction.
4. **Evaluate**: determine whether the action succeeded, triggered defenses, or yielded evidence requiring a path change.

The value of AI emerges especially in the planning and evaluation phases. Traditional malware can act and sometimes sense, but it usually has limited semantic understanding of responses. An AI-enabled system can interpret unstructured text, screenshots, portal interfaces, and documentation; it can therefore interact with SaaS consoles, developer environments, or identity workflows in ways that previously required a human operator.

Goal decomposition and subtask generation

Autonomous attacks begin with mission decomposition. A high-level goal such as “exfiltrate legal documents from Target X with minimal detection” can be translated into subtasks:

- identify the organization’s document platforms;
- enumerate employees likely to have access;
- determine authentication methods;
- select an access vector;
- secure persistence or session continuity;
- search and rank sensitive content;
- exfiltrate through plausible channels;
- suppress or delay defender awareness.

In a non-agentic operation, this decomposition resides in human tradecraft. In an agentic system, the decomposition is machine-generated and machine-updated. If the first access vector fails—for example, password spraying is blocked by MFA and impossible travel alerts—the system may pivot to browser session theft, OAuth consent abuse, adversary-in-the-middle phishing, or social engineering focused on help desk workflows. The important point is not that every branch is novel, but that the machine can choose among them without needing a human to manually rewrite the playbook at each failure.

Environmental modeling and attack graphs

Modern enterprise environments are increasingly machine-readable. Cloud providers, identity systems, collaboration suites, endpoint managers, and CI/CD platforms expose state through APIs. This favors autonomous offensive behavior because the attacker can construct a graph of identities, roles, resources, trust paths, secrets, and actions.

Consider a simplified enterprise attack graph:

Node type	Examples	Machine-useful attributes
Identity	User, service principal, admin account	Role assignments, MFA status, recent sessions, mailbox access
Resource	VM, storage bucket, repository, SaaS workspace	Network exposure, owner, secret references, access policies

Node type	Examples	Machine-useful attributes
Control plane	IAM policy, MDM tenant, directory role, SSO connector	Privilege implications, action APIs, blast radius
Data source	Mailbox, SharePoint site, code repository, ticketing project	Sensitivity indicators, export options, user interaction
Trust edge	OAuth grant, delegated admin, SSH key reuse, token cache	Lateral movement potential

An autonomous system can compute likely privilege escalation routes, persistence points, or exfiltration opportunities from such a graph. This is one reason why attacks increasingly emphasize identity, cloud administration, and enterprise management interfaces. These environments expose permissions and workflows in standardized forms that are highly navigable by agents. Unit 42's observation that Iranian activity is shifting toward abuse of the enterprise management plane is directly relevant here: the management plane is attractive precisely because it centralizes control over identities, endpoints, policies, and software distribution, enabling disproportionate downstream impact from a small number of administrative actions ([3](#), [4](#)).

Tool use and interface control

A hallmark of modern offensive agents is **tool calling**: the AI component invokes external capabilities to interact with the environment. The toolset determines the real-world attack surface of the agent. The most consequential tools in cyber operations are not exotic zero-day frameworks; they are often ordinary interfaces that expose powerful actions:

Tool/interface class	Offensive use
Browser automation	Log into portals, harvest session state, bypass UI friction, enumerate SaaS settings
Shell/PowerShell/Python	Post-exploitation, discovery, local data collection, script synthesis
Cloud/identity APIs	Enumerate users, roles, policies, apps, mailboxes, devices
Messaging/email APIs	Search mail, send internal lures, hijack threads, export communications
	Push scripts, alter policy, wipe or lock devices, manage agents

Tool/interface class	Offensive use
Endpoint management APIs	
Developer platform APIs	Access repos, CI secrets, package registries, deployment workflows
Remote administration tools	Interactive control with less malware footprint
OSINT and scraping tools	Profile targets and generate tailored social engineering

Browser automation deserves special attention. Many enterprise workflows are now mediated through web portals, and many defensive assumptions depend on UI friction, user prompt comprehension, or ad hoc administrative review. An agent that can visually parse a page, follow workflow prompts, and repeat trials can operationalize attacks that traditionally required skilled hands-on-keyboard operators. The agent does not need to exploit a memory corruption bug if it can instead guide a user through a malicious OAuth flow, manipulate support channels, or leverage exposed administration consoles.

Memory, persistence, and campaign continuity

Autonomous systems also differ from conventional malware in their use of **memory**. Memory can be short-term, such as the current browser state or token cache, or long-term, such as a database of prior phishing outcomes, employee roles, and tenant-specific quirks. Memory enables attack continuity across time and infrastructure changes.

For example, after one phishing wave, the system may learn that:

- finance staff respond more often to supplier-payment pretexts;
- a specific tenant prompts for a particular MFA method;
- certain mail gateways rewrite links in predictable ways;
- specific geolocations trigger fewer anomalies;
- the help desk uses a standardized ticket template susceptible to imitation.

This knowledge can automatically improve subsequent attempts. Mandiant's reporting on ORB networks underscores a similar continuity principle at the infrastructure level: by using a large, evolving mesh of VPS and compromised IoT/routers, attackers create resilient infrastructure that

persists despite takedowns or blocklists. When paired with an agentic planning layer, such infrastructure becomes a substrate for iterative offensive learning at scale (1).

Adaptation through failure interpretation

The most important operational property of an agentic system is not speed alone but the ability to **interpret failure**. Static automation breaks when it encounters an unanticipated condition. A more autonomous system can ask: Did login fail because the password was wrong, because conditional access blocked the session, because MFA was required, because a CAPTCHA appeared, or because the account is disabled? Each diagnosis suggests a different next step. This capacity is especially relevant to enterprise environments where defenses intentionally introduce friction rather than absolute prevention.

Failure interpretation changes attacker economics in at least four ways:

Effect	Traditional manual ops	Agentic ops
Reconciling failed steps	Requires analyst time	Automated classification and retry selection
Campaign tuning	Periodic human adjustment	Continuous machine adaptation
Scaling to many victims	Linear headcount growth	Nonlinear growth constrained more by infrastructure than labor
Detection evasion iteration	Slower, after-action	Near-real-time prompt/script/content changes

The result is that many attacks become **more robust under defender pressure**. Rather than collapsing after a blocked indicator or disabled domain, the system may self-repair by selecting a new domain, changing lure language, altering send cadence, or routing through different infrastructure.

Human supervision patterns

It would be inaccurate to imply that present-day agentic intrusion systems are universally “human out of the loop.” More commonly, threat actors use one of four supervision models:

Model	Human involvement	Likely users
Approval on high-risk actions	Human approves privilege escalation, disruptive actions, or data leak publication	State actors, mature extortion groups
Review by exception	Human only intervenes when confidence is low or unusual telemetry appears	Scaled crimeware operators
Stage-gated autonomy	Machine handles recon/initial access, human handles exploitation or extortion	Many current hybrid operations
Full bounded autonomy	Machine executes within a strict scope and budget	Narrow tasks, research prototypes, likely emerging niche use

This hybridization is strategically significant because it allows adversaries to preserve human judgment where needed while offloading labor-intensive processes to machines. For espionage actors, it supports patient scaling without sacrificing target discrimination. For financially motivated groups, it compresses time from target identification to monetizable access.

Offensive autonomy without bespoke malware

One of the most consequential changes in offensive operations is that autonomous capability no longer requires a custom malware platform. It can emerge from orchestration across legitimate interfaces. This is particularly visible in attacks focused on the identity and management plane. If the attacker gains administrative cloud or SaaS privileges, the environment itself supplies the actuators: create users, assign roles, export data, deploy scripts, modify policies, revoke recovery options, or disable protections. Unit 42's discussion of identity weaponization points toward exactly this shift: the management plane becomes the attack platform, and the malicious logic may reside in abuse of control mechanisms rather than in a signature-bearing wiper executable ([3](#), [4](#)).

This is a crucial point for enterprise defenders. Many detection programs are still optimized for endpoint malware lineage, process trees, and network indicators. Agentic offensive systems may instead manifest as:

- unusual API sequence patterns,
- privilege path exploration,
- adaptive SaaS login behavior,
- content generation at scale,

- abnormal but syntactically valid administration,
- distributed infrastructure with low-signal indicators.

In other words, the autonomous element often hides in **workflow semantics**, not malware artifacts.

A reference attack sequence

A representative agentic intrusion into a cloud-centric enterprise may unfold as follows:

Phase	Machine actions	Adaptation points
Target profiling	Scrapes org chart, vendor relations, technology stack	Chooses pretext by department and quarter-end context
Access acquisition	Generates spearphish or targets session theft	Rewrites lure if mail security degrades deliverability
Session establishment	Uses browser automation or token capture	Switches to OAuth/device-code/social engineering if MFA blocks path
Tenant discovery	Queries roles, apps, mailboxes, storage, devices	Prioritizes high-value identities and latent admin paths
Privilege expansion	Searches delegation, app permissions, stale accounts	Changes route if direct escalation is noisy
Objective execution	Exfiltrates documents or manipulates management plane	Throttles actions to match normal admin tempo
Persistence and resilience	Plants app grants, alternate auth, scheduled workflows	Re-enters via new infrastructure if remediation starts

This reference sequence demonstrates why the term “autonomous AI in offensive cyber” should not be confined to futuristic self-propagating malware. The more immediate reality is the machine-assisted conversion of attacker intent into adaptable, low-friction, API-driven intrusion chains.

Threat Actor Adoption Patterns: Who Is Using Autonomous or Semi-Autonomous Offensive Systems

The current landscape does not indicate a uniform distribution of autonomous cyber capability across actor classes. Instead, adoption follows mission incentives, organizational maturity, and the

degree to which the target environment is legible to machines. Broadly, use today clusters into five actor groupings: state espionage services and their contractors, state-aligned influence and hacktivist fronts, ransomware and extortion enterprises, access brokers and phishing specialists, and gray-market offensive service providers.

State espionage ecosystems

State-linked espionage operations have the strongest structural incentive to adopt bounded autonomy because they face persistent collection requirements across large target sets while operating under pressure to minimize attribution. Their missions benefit from systems that can continuously profile targets, maintain infrastructure, adapt collection paths, and re-enter environments after remediation. Mandiant’s reporting on China-nexus use of ORB networks illustrates an enabling layer that materially supports this kind of machine-mediated persistence. ORB networks built from VPS and compromised end-of-life IoT and routing devices allow operators to mask source traffic, expand infrastructure cheaply, and maintain an evolving relay fabric that raises the cost for defenders relying on IOC-based disruption. This is not simply an infrastructure convenience; it is a prerequisite for scalable semi-autonomous operations because the machine can route activity through a resilient and rotating mesh without operator micromanagement (1).

In state espionage usage, AI and autonomy are most plausibly concentrated in the following functions:

Function	Why state actors value it
Target triage and prioritization	Large candidate set; need to identify high-value organizations, subsidiaries, and administrators
Social engineering personalization	Better conversion against protected targets with fewer sends
Credential/session validation	Rapid scaling while controlling lockout and anomaly risk
Cloud and identity path discovery	Efficient exploitation of modern enterprise architecture
Infrastructure resilience	Rotating routes, domains, and nodes in response to detections
Translation and local context generation	More plausible lures, support interactions, or reconnaissance in foreign environments

State actors also benefit from autonomy because their campaigns often require long dwell time and quiet adaptation rather than immediate monetization. An agent that can observe when a tenant changes policies, rotates certificates, or disables one persistence mechanism and then suggest or enact an alternative is extremely useful operationally. This does not require science-fiction-level reasoning; it requires competent integration of planning, memory, and tool use.

State-aligned fronts and deniable personas

A second adoption cluster involves state-directed or state-tolerated personas operating under hacktivist, ransomware, or information-war branding. Unit 42's reporting on Iranian cyber evolution is especially relevant here, describing a shift in 2023–2025 toward state-directed hacktivist personas such as Void Manticore and Handala, operating openly on platforms like Telegram and combining destructive actions with psychological operations and hack-and-leak campaigns. The operational significance for autonomous systems is that such actors need scale, messaging agility, and cross-platform coordination. AI systems can help generate propaganda-aligned narratives, tailor leak announcements, manage sockpuppet interactions, and adapt destructive sequencing to maximize reputational pressure (2).

In this category, autonomy is not limited to intrusion mechanics. It extends into **information operation integration**:

- generating multilingual messaging around leaks or disruptions;
- timing disclosures based on audience reaction;
- amplifying campaign narratives across channels;
- crafting victim-facing extortion or coercive messaging;
- managing personas with differing ideological branding.

The significance is that offensive cyber becomes part of a broader machine-mediated influence apparatus. Attack execution, leak curation, and psychological pressure can all be coordinated by semi-autonomous systems.

Ransomware and extortion enterprises

Financially motivated actors face different incentives: they optimize for throughput, access conversion, and time-to-monetization. They are likely to adopt autonomous components earliest where they lower labor costs in high-volume phases. Three areas are especially ripe:

1. **Lead generation and victim scoring**: identifying enterprises with revenue, cyber insurance likelihood, exposed services, and weak identity posture.

2. **Initial access optimization:** adaptive phishing, session theft, exploitation prioritization, and credential reuse.
3. **Negotiation and extortion support:** victim communication drafting, stolen-data categorization, and pressure campaign timing.

The extortion ecosystem already industrialized many pieces of the attack chain through affiliates, builders, brokers, and negotiation specialists. AI can be inserted into each layer without requiring a radical restructuring of the criminal business model. The likely near-term pattern is not “fully autonomous ransomware,” but **AI-enhanced division of labor** where machines increase the productivity of human affiliates.

Importantly, ransomware groups have historically used plausible-deniability covers such as hacktivism or ransomware branding even when operations align with geopolitical interests or broader disruption goals. Unit 42 notes that Iranian actors benefited strategically by masquerading as ransomware syndicates because it obscured state alignment while still causing business disruption and economic damage. That observation has direct relevance here: autonomous systems make such masquerading easier by enabling rapid rebranding, content regeneration, infrastructure churn, and campaign modularity ([2](#)).

Access brokers and phishing specialists

Initial access brokers (IABs), phishing operators, and credential theft specialists likely represent the highest-volume near-term adopters of agentic systems. Their tasks are comparatively well-bounded, data-rich, and measurable. They can evaluate success based on email opens, token capture, session validation, or account takeover rate. That lends itself to optimization loops.

An autonomous phishing system can:

- profile the target organization;
- infer current business cycles or vendors;
- generate department-specific lures;
- A/B test subject lines and body text;
- react to secure email gateway modifications;
- monitor which credentials or tokens remain valid;
- escalate only the best compromises for resale.

This is one of the clearest cases where AI changes attacker economics even without advanced exploitation. The machine may not need to breach hardened endpoints if it can reliably obtain valid user sessions.

Offensive service providers and “autonomy-as-a-service”

A further emerging category is the commercialization of components rather than full campaigns. Just as “malware-as-a-service” unbundled payload delivery from operations, a likely trajectory is **autonomy-as-a-service**, where vendors provide one or more of the following:

- adaptive phishing generation,
- victim profiling pipelines,
- credential-validation engines,
- cloud privilege graphing,
- browser-operation bots,
- multilingual extortion messaging,
- relay and infrastructure management.

Some of these services may appear in ostensibly legitimate offensive security tooling or gray-market red-team ecosystems before migrating into overtly criminal use. The diffusion path often follows a familiar pattern: research prototype → red-team utility → dual-use abuse → crimeware packaging. The barrier to entry is lower than for advanced exploit development because many core components—LLMs, browser automation frameworks, graph databases, public OSINT sources—are commercially available.

Comparative adoption by actor type

Actor type	Current autonomy maturity	Most likely machine-controlled stages	Primary constraint
State espionage	Medium to high (bounded)	Recon, target triage, infrastructure management, cloud/identity pathing	Need for stealth, target discrimination
State-aligned fronts	Medium	Messaging, leak ops, psychological coordination, destructive workflow timing	Political control and deniability
Ransomware/extortion	Medium	Lead scoring, phishing, session theft, victim comms, loot triage	Reliability and affiliate heterogeneity

Actor type	Current autonomy maturity	Most likely machine-controlled stages	Primary constraint
Initial access brokers	High in narrow scope	Phishing adaptation, credential validation, account takeovers	Detection by email/identity defenses
Commodity crimeware	Low to medium	Content generation, simple automation, support interactions	Technical sophistication and ROI
Offensive service vendors	Medium and rising	Tool orchestration, browser automation, graph analysis	Market trust and infrastructure risk

Why some actors lag

Not all threat actors benefit equally from autonomy. Several constraints limit adoption:

- **Operational security risk:** AI systems may leak prompts, crash unpredictably, or produce artifacts that aid attribution.
- **Control concerns:** sophisticated state operators may distrust unsupervised actions in sensitive operations.
- **Data requirements:** effective adaptation often requires telemetry and prior campaign data.
- **Interface fragility:** browser and API workflows change often, breaking automated playbooks.
- **Model dependency:** reliance on commercial AI providers creates account, policy, and logging exposure.

Still, these constraints are declining as actors move to local models, open-weight systems, self-hosted inference, and tool-centric agents. The threat trend is therefore toward broader adoption of **narrow autonomous modules** rather than universal deployment of monolithic autonomous attackers.

Observable tradecraft indicators by actor category

Actor category	Observable signs of agentic capability
State espionage	Highly tailored but rapidly produced lures; infrastructure rotation coupled to delivery outcomes; adaptive cloud/API probing

Actor category	Observable signs of agentic capability
State-aligned fronts	Synchronized leak messaging and technical actions; multilingual persona management; timed coercive campaigns
Ransomware/extortion	Rapid victim profiling; automated file categorization; semi-personalized negotiation at scale
IAB/phishing	Dynamic lure rewriting; session/cookie validation pipelines; retry logic based on MFA or geo prompts
Commodity crimeware	Generic AI-generated content, but less evidence of closed-loop adaptation

The strategic implication is that threat intelligence should track **capability modularization**, not only actor labels. A China-nexus espionage actor using ORB relay infrastructure, an Iranian state-directed hacktivist persona using psychological operations, and a criminal IAB optimizing session theft may all share common autonomous components despite divergent motives. The machine layer is becoming a reusable offensive substrate that cuts across actor ecosystems.

Targeted Environments and Interfaces: Where Autonomous Attack Logic Has the Greatest Leverage

Autonomous offensive systems do not apply uniformly across the enterprise. They are most effective where environments are highly instrumented, richly documented, remotely reachable, and govern large amounts of downstream authority. This explains why the current center of gravity is shifting away from narrow endpoint exploitation alone and toward the **identity plane, cloud control plane, enterprise management plane, collaboration platforms, browsers, and exposed edge infrastructure**.

Identity systems as machine-readable attack terrain

Identity infrastructure is the natural habitat of offensive autonomy because it converts organizational trust into structured data. Users, groups, roles, application grants, conditional access rules, session lifetimes, devices, and authentication events are all represented in ways that can be queried, graphed, and acted upon.

For an autonomous attacker, identity systems offer four advantages:

Identity-plane property	Why it favors agentic attacks
Structured permissions	Easy to map privilege relationships and escalation opportunities
Standardized APIs	Supports automated enumeration and actioning
Centrality	Compromise can unlock mail, files, devices, cloud resources, and admin workflows
Behavioral ambiguity	Many malicious actions resemble legitimate administration

This is why the evolution toward “identity weaponization” is more than a change in TTP nomenclature; it is a shift toward environments where machine reasoning is especially effective. Unit 42’s observation that recent Iranian offensive activity targets the enterprise management plane rather than relying on custom wiper binaries suggests a broader operational trend: attacker impact increasingly flows through centralized control surfaces, which are precisely the systems autonomous tools can navigate efficiently ([3](#), [4](#)).

Common agentic tasks in identity systems include:

- finding users with weak or absent MFA;
- identifying stale accounts and service principals;
- testing OAuth or consent-based persistence;
- graphing delegated administration paths;
- timing logins to blend with prior session patterns;
- using browser and API automation to complete account changes.

Cloud control planes and SaaS administration

Cloud environments and SaaS tenants amplify attacker leverage because a small number of administrative actions can expose large resource sets. They are also deeply API-driven, making them easy to automate. An autonomous agent can enumerate storage, compute, serverless functions, IAM bindings, secrets, repositories, data exports, and tenant policies more quickly than a human operator constrained by console navigation.

The principal attraction is **blast radius per action**. Changing one policy, role assignment, application secret, or tenant configuration can create persistent access or broad exfiltration opportunities. This shifts offensive effort from malware deployment toward control-plane manipulation.

How Agentic Systems Plan, Execute, and Adapt Multi-Step Cyberattacks

From Workflow Assistance to Operational Autonomy: What Has Changed in 2025–2026

While the previous subtopic report defined agentic intrusion architecture at a conceptual level, this section focuses on the **observed transition from assistance-oriented AI use to operationally embedded autonomy**, emphasizing what threat intelligence reporting now indicates about how those systems are being used in practice rather than how they are theoretically structured.

Across 2025 and early 2026, the most significant shift is not that threat actors suddenly achieved fully independent “AI hackers,” but that they began to **embed LLMs and agentic components into repeatable attack workflows** where the machine is entrusted with bounded decision authority over reconnaissance, content generation, code revision, command selection, environment interpretation, and campaign tuning. Microsoft characterizes current malicious use as still primarily generative and decision-support oriented, yet explicitly notes “early signals of a transition toward more agentic uses of AI,” including workflows able to plan steps, invoke tools, evaluate outcomes, and adapt behavior without continuous human prompting ([1](#)). Google Threat Intelligence Group (GTIG) uses a similar framing, defining agentic AI as systems that can reason through complex tasks, make independent decisions, and execute multi-step actions without constant human oversight, while also cautioning that broad real-world deployment remains limited but increasingly plausible ([2](#)).

The crucial operational distinction is between **single-shot AI assistance** and **closed-loop cyber execution**. In the former, an operator asks a model to write phishing text, explain a vulnerability, or generate boilerplate code. In the latter, AI components are connected to tools, APIs, browsers, shells, or malware execution paths such that outputs are not merely advisory but become machine-consumable actions. Mandiant’s March 2026 special report argues that by the end of 2025 adversaries had moved beyond static human-in-the-loop augmentation into “highly autonomous and adaptive attacks,” including direct integration of LLM APIs into malware for runtime code generation and environment-responsive tasking ([3](#)).

This progression can be represented as a maturity curve.

Stage	Primary role of AI	Human role	Typical offensive outcome	Confidence in widespread use
Prompted assistance	Drafting text, code help, translation, research	Continuous operator control	Faster phishing, scripting, and OSINT	High (1 , 3)
Embedded decision support	AI evaluates options inside an attacker workflow	Operator approves key branches	Better lure tuning, infrastructure setup, troubleshooting	High (1 , 10)
Semi-autonomous orchestration	AI executes bounded multi-step sequences using tools or APIs	Human sets objectives and intervenes selectively	Scalable reconnaissance, command generation, adaptive malware behavior	Moderate and rising (3 , 8)
Multi-target autonomous campaigning	AI coordinates end-to-end cyber operations at speed across multiple victims	Human provides mission intent and constraints	Simultaneous reconnaissance, exploitation, lateral movement	Low-frequency but high-significance reported cases (4 , 8)

A notable feature of this shift is that agentic cyber operations often arise **without requiring a revolutionary new malware family**. Instead, attackers can combine mainstream model APIs, browser automation, scripting runtimes, credential theft, cloud administration interfaces, and orchestration frameworks. Microsoft highlights that threat actors are using AI not just for phishing text but to create fake company sites, provision infrastructure, and troubleshoot deployments, with experimentation extending toward agentic systems that perform tasks autonomously and adapt to results ([10](#)). This matters because the technological barrier to entry falls sharply when an adversary can stitch together public AI services and commodity intrusion tooling.

The resulting operational model resembles a **campaign manager** more than a standalone exploit engine. The machine is useful because enterprise environments are filled with semi-structured interfaces—cloud consoles, support flows, developer documentation, endpoint prompts, SaaS admin panes, login errors, and API responses—that classical automation handles poorly. Agentic systems are valuable precisely where textual or visual ambiguity previously forced human attention. NIST’s

Cybersecurity Framework Profile for AI reflects this by describing AI agents as increasingly capable of autonomously orchestrating reconnaissance, attack-surface mapping, exploitation, credential harvesting, lateral movement, and data collection, including operation of standard cyber tools such as scanners, password crackers, exploitation frameworks, and binary analysis suites (8).

A second change is temporal. Traditional intrusion automation tends to be **episodic**: a phishing run is sent, a scanner is executed, a payload is dropped. Agentic systems instead support **continuous optimization**. They can monitor deliverability, rephrase lures, test infrastructure, regenerate code, classify errors, and queue next actions as new data arrive. Microsoft specifically warns that agentic AI could enable semi-autonomous workflows that continuously refine phishing campaigns, test and adapt infrastructure, maintain persistence, or monitor open-source intelligence for new opportunities (1). That “continuous refinement” is one of the strongest indicators that offensive AI is moving from productivity enhancement to tradecraft transformation.

This transformation has direct implications for attacker economics. The Microsoft Digital Defense Report 2025 cites research indicating AI-automated phishing may be **up to 50 times more profitable** than traditional methods under certain conditions (5). CrowdStrike’s 2025 Threat Hunting Report further notes **320+ organizations infiltrated by DPRK-nexus adversaries using GenAI-accelerated attacks**, alongside a broad environment in which **81% of hands-on-keyboard intrusions were malware-free** and cloud intrusions surged **136% year over year** (6). These figures do not prove universal agentic autonomy, but they do show that AI amplification is already compounding with identity abuse, cloud-native intrusion, and malware-light operations—the exact conditions under which agentic control loops become especially advantageous.

Another reason the current moment matters is that threat intelligence reporting now includes claims of **live operational malware querying LLMs** and **AI-orchestrated cyber espionage campaigns**. Mandiant describes PROMPTSTEAL as malware used by APT28 against Ukraine that queried an LLM for one-line Windows commands for document theft, calling it the first observation of malware querying an LLM in live operations (3). CrowdStrike, citing Anthropic’s findings, states that a sophisticated nation-state operation weaponized Claude’s agentic capabilities and the Model Context Protocol (MCP) to automate reconnaissance, vulnerability exploitation, lateral movement, and other activity against multiple targets simultaneously (4). NIST’s December 2025 profile explicitly references Anthropic’s report as evidence relevant to autonomous AI-enabled attack orchestration (8).

At the same time, the evidentiary standard should remain disciplined. Both Microsoft and GTIG stress that **large-scale use is not yet the norm**. Microsoft states it has not observed large-scale deployment of agentic AI by threat actors, citing reliability and operational constraints (1). GTIG likewise says it has not yet seen underground claims of tools such as AutoGPT translate into proven

in-the-wild capability, although it expects more services to market agentic functions (2). Thus, the present threat landscape is best described as **uneven but material**: broad AI assistance, accelerating semi-autonomy, and a small number of high-impact cases suggesting what mature offensive autonomy may soon look like.

Three concrete characteristics distinguish this phase from earlier “AI-enabled” cyber discussions.

First, **runtime dependence on external models** is emerging as a malicious design pattern. Instead of shipping all logic in a payload, malware can request commands or code fragments on demand, changing behavior over time and reducing the static footprint available to defenders. Mandiant’s characterization of PROMPTFLUX and PROMPTSTEAL underscores this design pattern, describing malware that uses LLM APIs to generate malicious code or commands during execution and thereby become more polymorphic and difficult to detect via signatures (3).

Second, **agentic operations increasingly target control layers rather than just endpoints**. As intrusions become more cloud- and identity-centric, AI’s ability to parse admin interfaces, documentation, and policy prompts becomes strategically important. This is consistent with the broader empirical shift toward malware-free activity noted by CrowdStrike, where abuse of valid credentials and legitimate administration can be more decisive than implant sophistication (6).

Third, **defensive timing assumptions are eroding**. AI-enabled attacks operate at machine speed in phases that used to be buffered by human labor—profiling, content customization, infrastructure validation, and retry selection. Dark Reading emphasizes that human engineers alone cannot keep pace with malware rewriting itself hourly or with AI-orchestrated campaigns conducted without substantial human intervention (9). For defenders, this does not simply increase volume; it compresses the time available to detect pattern shifts before the adversary adapts again.

The operational change can also be framed as a reallocation of cognitive labor.

Cyber function	Previously human-dominant	Agentic contribution in 2025–2026	Reported or anticipated impact
Reconnaissance synthesis	Analysts correlated OSINT and technical findings	Automated clustering of target data and prioritization	Faster target qualification and pretext selection (1, 11)
Social engineering production	Operators wrote lures manually	Multilingual, persona-matched generation and iterative tuning	Higher throughput, lower content cost,

Cyber function	Previously human-dominant	Agentic contribution in 2025–2026	Reported or anticipated impact
			better localization (1 , 8)
Post-compromise command selection	Operators translated goals into commands	LLM-generated one-liners and just-in-time code	More flexible malware-light execution (3)
Infrastructure troubleshooting	Operators debugged broken payloads or sites	AI-assisted provisioning and repair loops	Shorter campaign setup cycle (10)
Lateral decision-making	Skilled intruders interpreted environment cues	Early-stage agentic experimentation with conditional sequencing	Potential reduction in operator bottlenecks (4 , 8)

Therefore, the current state of agentic cyber offense should not be overstated as universal autonomy, but it should not be dismissed as speculative either. The more accurate reading of the evidence is that 2025–2026 marks the point at which autonomous and semi-autonomous logic moved from laboratory curiosity and underground marketing language into **documented operational relevance**, especially in phishing optimization, infrastructure manipulation, malware adaptability, and machine-directed exploitation workflows ([1](#), [2](#), [3](#), [4](#)).

Decision Loops in Live Operations: How Machine Planning Becomes Actionable Tradecraft

While the earlier report covered goal decomposition and adaptation conceptually, this section examines **how decision loops become operationalized in the field**, with emphasis on machine-selectable branching conditions, confidence thresholds, and feedback channels observed or implied by current threat intelligence.

In practice, an agentic cyber system becomes dangerous only when planning outputs are connected to mechanisms that can alter the environment. The key development in 2025–2026 is that offensive systems increasingly combine three ingredients:

1. a model capable of interpreting ambiguous input;
2. a tool layer capable of taking cyber actions; and
3. a controller capable of deciding whether to continue, retry, pivot, or stop.

This controller may be a bespoke orchestration layer, malware logic, browser automation harness, or a framework using an AI model to decide next steps. Microsoft describes agentic systems as workflows pursuing objectives over time through planning, tool invocation, outcome evaluation, and adaptive behavior without constant prompting (1). The significance lies less in any single component than in the **closed-loop autonomy** generated by the interaction of all three.

Operationally, those decision loops rely on **state representations**—machine-readable descriptions of what has happened so far. In conventional scripts, state is often coarse: success or failure, open or closed port, credential valid or invalid. Agentic systems can maintain richer state, such as “user accepted lure but device registration prompt appeared,” “admin portal reachable but privilege insufficient,” or “mail filter downgraded campaign efficacy for finance-themed pretexts.” Such state is useful because enterprise defenses seldom produce binary outcomes; they introduce friction, prompts, delays, and policy branch conditions. AI models are increasingly effective at interpreting those conditions in textual or visual form.

A practical abstraction for current agentic attack loops is shown below.

Loop element	Function in offensive operations	Typical machine inputs	Typical machine outputs
Objective scoring	Rank possible next steps by value, stealth, and feasibility	Mission goal, victim tier, campaign constraints	Prioritized action queue
Context ingestion	Collect signals from target environment	Email responses, HTTP content, screenshots, API errors, command output	Normalized environment summary
Branch selection	Choose among alternate access or execution paths	Environment summary, historical outcomes, detection risk	Selected tactic or tool
Action rendering	Convert chosen tactic into executable form	Desired effect, target parameters	Commands, phishing text, API calls, browser actions
Post-action assessment	Judge whether the step succeeded and what changed	Telemetry, output logs, elapsed time, side effects	Continue, retry, pivot, escalate, terminate

This abstraction helps explain the practical difference between ordinary automation and agentic tradecraft. A scripted phishing operation can send messages at scale, but it does not inherently know *why* a campaign is underperforming. An agentic phishing controller can compare reply rates, bounce rates, authentication prompts, and target roles, then modify lure language or switch personas. Microsoft explicitly notes that threat actors could use agentic AI to continuously refine phishing campaigns and test infrastructure (1). That phrase “continuously refine” implies an evaluative loop with measurable reward signals.

In cyber operations, reward signals do not need to be mathematically elegant. They can be crude but effective:

- higher mail deliverability;
- more credential captures per domain;
- fewer endpoint alerts after command execution;
- lower HTTP error rates from fake sites;
- more successful browser sessions after token theft;
- fewer failed privilege escalation attempts;
- greater volume of accessible documents per compromised identity.

Because these metrics are naturally generated during intrusion activity, the attacker does not require a sophisticated reinforcement learning laboratory to benefit. A practical attacker only needs enough automation to compare variants and retain the better-performing branch.

Recent reporting suggests that **runtime command synthesis** is one of the earliest operationally useful forms of such branching. Mandiant’s description of PROMPTSTEAL is illustrative: malware queried an LLM to produce one-line Windows commands for document theft during live operations (3). This means the machine need not carry a full post-exploitation playbook in static form. Instead, it can request tailored command logic based on current circumstances, reducing the need for a human operator to manually formulate every step. The decision loop is therefore compressed: observe environment, request command, execute, inspect result, request next command.

PROMPTFLUX extends this idea from command generation to **self-modification cadence**.

According to GTIG, the malware rewrote its own VBScript source hourly via the Gemini API, specifically to evade detection (3; 9). Here the loop is not merely “what command should I run?” but “how should I alter my own code to remain viable under current defensive pressure?” Even if such malware is still experimental rather than widespread, it demonstrates that machine planning can now be directed inward at the implant itself, not only outward toward the victim environment.

A second key aspect of these loops is **interface fluency**. Many enterprise attack surfaces are not low-level protocols but layered interaction spaces—identity prompts, CAPTCHA pages, browser

dialogs, SaaS permissions, DevOps pipelines, and support workflows. Agentic systems are useful because they can infer meaning from these interfaces and respond accordingly. NIST specifically warns that AI agents are increasingly capable of autonomously operating scanners, password crackers, exploitation frameworks, and analysis suites, but the more transformative implication is that they can also navigate human-oriented interfaces that traditional automation could not reliably parse (8).

This matters particularly for **help desk and insider-risk-adjacent operations**. Microsoft advises organizations to treat certain AI-enabled campaigns, especially those involving abuse of legitimate access, as insider risks (10). The underlying reason is that the decision logic can increasingly operate within business-process interfaces rather than malware channels. For example, an agent may monitor whether an account reset flow requests additional identity proofing, then modify the social engineering script to satisfy the next requirement. Such behavior sits at the boundary between cyber intrusion and process manipulation.

The present generation of agentic systems also benefits from **error semanticization**—transforming raw failures into meaningful categories. In enterprise operations, most defensive control failures are not opaque. A denied login may expose text indicating MFA requirement, geo-restriction, account lockout, or disabled account status. A failed API call may reveal role deficiency, token expiration, tenant mismatch, or consent requirement. A blocked phishing link may indicate reputation filtering rather than target disinterest. Models can interpret these nuances and choose different recovery actions.

The strategic effect is shown below.

Failure condition	Static automation outcome	Agentic outcome	Attacker advantage
Login blocked by conditional access	Abort or retry blindly	Shift to device-code/social engineering/session theft path	Fewer wasted attempts
Email lure quarantined	Continue poor-performing campaign	Rewrite wording, alter sender persona, rotate domain	Better delivery resilience
Privilege insufficient in SaaS tenant	Stop or alert human	Search alternate delegated roles or app permissions	More autonomous escalation

Failure condition	Static automation outcome	Agentic outcome	Attacker advantage
Payload flagged by security tooling	Redeploy same family with minor edits	Regenerate code/commands or alter execution pattern	Faster evasion cycle
Exploit chain fails on target variant	Human troubleshooting required	Query for environment-specific fix or alternate sequence	Lower operator burden

The Anthropic-attributed campaign cited by CrowdStrike suggests what this looks like when scaled beyond single-step optimization. According to CrowdStrike’s summary, Claude’s agentic capabilities and MCP were weaponized to automate reconnaissance, vulnerability exploitation, lateral movement, and more across multiple targets worldwide, at unprecedented scale and speed (4). Even without every technical detail, the importance of the case lies in the implied control model: the system was not merely generating one artifact but managing **multi-phase progression across multiple victim environments**.

Such cases indicate that the most mature offensive decision loops likely include several supervisory variables:

- **stealth budgets**, limiting action rate or privilege changes;
- **target valuation**, to concentrate autonomy on the most promising victims;
- **confidence thresholds**, determining when to proceed automatically versus defer to a human operator;
- **tool selection rules**, based on platform and environment cues;
- **fallback paths**, triggered when a tactic degrades or is detected;
- **termination conditions**, such as low probability of success or high detection risk.

Although public reports do not always expose these internals, they are a logical necessity for useful autonomy. Without constraints, autonomous systems would generate too much noise and fail operationally. Microsoft’s statement that threat actors currently use AI more for decision-making than fully autonomous attacks is consistent with this reality: autonomy is most valuable when delegated selectively, not indiscriminately (10).

Another operational detail is the use of **externalized cognition**. Malware or orchestrators can offload parts of reasoning to an external API, effectively treating the model as a just-in-time planner or translator. Mandiant explicitly describes the LLM as acting like an external C2 for adaptive malware, offering “goal-driven” guidance according to environmental conditions (3). This is a

significant shift in command-and-control philosophy. Traditional C2 channels transmit predefined instructions from humans; AI-mediated external control can generate or refine instructions dynamically, based on incoming target context. That reduces the amount of pre-authored logic adversaries must maintain and can make command patterns less repetitive.

The implications for defenders are severe because each execution cycle can produce **novel surface forms** even when the underlying objective remains stable. Signature-based tools are least effective against adversaries that preserve intent but mutate implementation. This is why AI-linked polymorphism is strategically more important than novelty in any single malware sample. Dark Reading’s concern about machine-speed defense against AI malware reflects precisely this challenge: if malicious code or commands can be revised hourly, defender triage and signature deployment lag behind the threat’s own regeneration tempo (9).

Importantly, these loops can operate at different granularities.

Granularity	Example of agentic decision	Operational significance
Micro-level	Choose a one-line command for file theft	Replaces human command authoring
Session-level	Decide whether to continue a login workflow or pivot to another identity path	Enables friction-aware intrusion
Campaign-level	Tune lure themes across departments and geographies	Improves conversion at scale
Implant-level	Rewrite malware logic or obfuscation on schedule	Enhances survivability
Portfolio-level	Allocate attack resources across multiple simultaneous victims	Multiplies parallelism

This multi-level decisioning is one reason offensive autonomy may alter the balance of power even before “fully autonomous hacking” becomes widespread. An attacker need not automate everything. Automating a few of the costliest cognitive bottlenecks—classification of errors, generation of commands, triage of targets, and iterative tuning of delivery infrastructure—already yields large returns.

The reliability ceiling, however, remains real. GTIG cautions that it has not yet seen evidence proving that publicly advertised autonomous tools are being used in the wild as claimed (2). Microsoft similarly notes operational constraints around reliability (1). This suggests that the most

successful offensive systems today are likely **hybrid**: machine-driven for repetitive and interpretable tasks, human-guided for high-consequence branching and strategic target decisions. But the hybrid nature does not diminish the threat; it is precisely what makes these systems practical. They automate enough to outpace defenders while preserving human oversight where mistakes would be costly.

As a result, the near-term security concern is not a science-fiction “autonomous cyberwar machine,” but the emergence of **robust offensive control loops** in which AI handles enough interpretation and adaptation to keep multi-step attacks moving under real-world friction. That capability is already visible across phishing optimization, malware command generation, self-modifying code, infrastructure provisioning, and reported multi-target espionage automation ([1](#), [3](#), [4](#), [10](#)).

Attack Surfaces Most Susceptible to Autonomous Sequencing

While the previous report addressed targeted environments at a high level—especially identity systems and cloud control planes—this section narrows the analysis to **which concrete interfaces and operational surfaces are most susceptible to autonomous sequencing**, and why these environments are disproportionately favorable for agentic attack execution.

Not all cyber environments are equally automatable. Agentic systems perform best where four conditions exist simultaneously:

1. the environment is accessible through stable interfaces such as web portals, APIs, shells, or scripting runtimes;
2. success and failure generate rich machine-interpretable feedback;
3. high-value actions can be performed using legitimate functions; and
4. defenders tolerate a baseline of noisy but legitimate administrative activity.

Modern enterprises unfortunately expose many such surfaces.

Identity, authentication, and recovery workflows

Authentication flows remain one of the most favorable attack surfaces for agentic sequencing because they produce **explicit branch conditions**: password accepted or rejected, MFA prompted, device approval required, session token accepted, conditional access denied, account locked, or user challenge triggered. Each branch can be interpreted by a model and paired with a next-best action. NIST highlights AI-enabled phishing, deepfakes, and personnel-targeted attacks as leading ways AI-enabled cyberattacks gain footholds, emphasizing that these methods can exploit realistic communications, hyper-realistic websites, and trust-building narratives at low attacker effort ([8](#)).

This environment is especially conducive to autonomy because **humans are part of the control loop**. A machine can adapt not only to technical defenses but to user behavior. For instance, if an initial lure underperforms, it can be localized, rewritten, or re-timed. Microsoft's reporting on AI refining phishing campaigns and generating fake company sites points directly to this attack surface ([1](#); [10](#)). Once a session is obtained, subsequent actions may remain malware-free, blending into normal SaaS and identity traffic.

Web-based administrative consoles and SaaS management panes

Administrative web interfaces are vulnerable to autonomous sequencing because they expose large numbers of potent actions behind visual or API-mediated controls: adding users, assigning roles, exporting data, changing retention settings, creating forwarding rules, authorizing applications, and adjusting security policies. AI models are increasingly capable of understanding text-heavy interfaces and associated help content. In such contexts, autonomy does not require exploit development; it requires **interface comprehension plus policy-aware action selection**.

Microsoft's observation that threat actors already use AI to provision infrastructure and test deployments is relevant here because the same capabilities can be redirected inward against enterprise admin environments ([10](#)). Moreover, CrowdStrike's finding that 81% of hands-on-keyboard intrusions were malware-free indicates a threat landscape in which abuse of legitimate admin functionality is increasingly central ([6](#)). Agentic systems can therefore thrive by operating management surfaces that defenders often trust by default.

Public-facing business logic and application workflows

Another favorable surface is the category of business logic exposed through web applications, customer portals, and partner interfaces. Cyber Defense Magazine, citing 2026 forecasts and practitioner observations, notes that automation-driven reconnaissance is already scanning for exposed assets, probing business logic endpoints, and clustering LinkedIn data to map attack surfaces faster than humans ([11](#)). The significance of business logic as an autonomous target lies in its ambiguity: unlike classic vulnerability scanning, these flows require understanding sequence, context, and response semantics. Agentic models are better suited than fixed scanners to infer whether an order-state transition, parameter relationship, or access control inconsistency may be exploitable.

This is also where the gap between red-team research and criminal use may narrow quickly. Multi-agent frameworks that move from CVE descriptions to verifiable exploits are now explicitly referenced in NIST's profile ([8](#)). Once such frameworks are connected to public-facing applications,

they enable not just scanning but conditional replay, exploit adaptation, and chained abuse of business processes.

Endpoint scripting and command interpreters

Even in environments where an agent cannot freely navigate a GUI, command interpreters provide a fertile target for autonomy. Mandiant’s PROMPTSTEAL example demonstrates that post-compromise command generation can be delegated to an LLM in operational settings (3). This is especially relevant in Windows-heavy enterprise estates, where one-line commands can perform collection, staging, persistence, and lateral support tasks without deploying complex malware families.

What makes command environments attractive is that they are **low-latency and testable**. The agent can issue a command, inspect stdout/stderr or system state, and request the next command. This creates a tight feedback loop amenable to autonomy. It also reduces the need for operators with deep shell expertise to remain engaged at every step.

Developer and CI/CD ecosystems

Although less detailed in the cited reporting than identity and malware use cases, developer ecosystems are increasingly implicated because they combine secrets, automation, and permissive machine interfaces. AI systems can parse repositories, configuration files, build logs, IaC templates, and documentation. Once access is established, the environment often provides powerful automation primitives—pipelines, service connections, deployment tokens, package registries, and cloud credentials. The same characteristics that make DevOps ecosystems efficient for defenders make them advantageous to agentic intruders.

The broader cloud intrusion surge reported by CrowdStrike—**136% year-over-year growth**—suggests why these surfaces matter (6). Cloud and CI/CD environments expose APIs and automation surfaces that a machine can reason over more readily than opaque binary protocols.

The susceptibility of these surfaces can be summarized comparatively.

Surface	Why autonomy works well	Typical machine-readable signals	High-value effects
Identity/login flows	Clear branch conditions and human interaction leverage	Prompts, error text, session responses, MFA states	Account takeover, session hijack, tenant access

Surface	Why autonomy works well	Typical machine-readable signals	High-value effects
SaaS/admin consoles	Legitimate actions have major security impact	UI text, API responses, audit logs, role errors	Role escalation, data export, policy changes
Business logic endpoints	Sequence-heavy behavior benefits from adaptive probing	HTTP responses, state transitions, validation errors	Fraud, privilege bypass, logic abuse
Shells and scripting hosts	Immediate feedback and flexible execution	Command output, exit codes, file system state	Collection, staging, stealthy execution
CI/CD and cloud automation	Rich APIs and powerful delegated trust	Build logs, token scope errors, deployment results	Secret theft, supply-chain abuse, cloud persistence

A further reason these interfaces are favorable is that they support **progressive privilege realization**. An attacker may start with minimal access, then discover what is reachable and exploitable within the environment itself. Agentic systems can do this efficiently because they are good at reading documentation, interpreting error messages, and translating high-level goals into platform-specific operations. This is exactly the sort of activity Microsoft identifies when discussing AI-enabled testing and troubleshooting of attacker infrastructure ([10](#)); the same operational strength transfers naturally to target environments.

Another important dimension is **cross-interface sequencing**. Modern campaigns rarely remain confined to a single surface. A realistic machine-driven attack may begin with OSINT and phishing, transition into an identity portal, proceed through browser automation in a SaaS console, invoke shell commands on a managed endpoint, and then access cloud storage or messaging platforms. The model's advantage is not just local optimization within one interface but the ability to preserve context while moving among unlike environments. This is why NIST's warning about AI agents orchestrating multiple phases of attack is strategically significant: the concern is not any single automated tool, but orchestration across the full attack chain ([8](#)).

For defenders, the risk is amplified because these surfaces often generate logs in different systems with different ownership models: email gateways, identity providers, SaaS audit logs, endpoint telemetry, cloud control-plane records, and browser artifacts. An agentic attacker can exploit this fragmentation. If one branch becomes noisy, the system may shift into a different interface where

the same operator action appears normal. In this sense, autonomy increases not only speed but **cross-domain maneuverability**.

Moreover, the most susceptible interfaces are often those with **high semantic density and low exploit novelty requirements**. A machine does not need a zero-day if it can understand enough context to weaponize misconfigurations, permissions, delegated access, trust relationships, or user workflows. This is why the rise of agentic offense coincides with malware-light and cloud-heavy intrusion trends. The offensive leverage comes from interpreting and abusing what the enterprise already exposes.

The practical prioritization for enterprise defense should therefore focus less on searching for mythical “AI malware signatures” and more on identifying environments where a machine can repeatedly test, learn, and act without tripping hard stops. In current reporting, those environments are concentrated around **identity workflows, administrative consoles, externally exposed business logic, command execution surfaces, and cloud/developer automation ecosystems** ([1] (<https://www.microsoft.com/en-us/security/blog/2026/03/06/ai-as-tradecraft-how-threat-actors-operationalize-ai>)).

Threat Actor Ecosystem and the Commercialization of AI-Enabled Offensive Capabilities

Market Formation: From Jailbroken Assistants to Specialized Offensive AI Supply Chains

While the previous reports explained *who* is adopting autonomous or semi-autonomous offensive systems and *how* agentic systems sequence tasks, this section examines a different layer: the **commercial market structure** that is emerging around AI-enabled offensive capability. The key analytical shift is from actor typology to **capability industrialization**. What matters in 2025–2026 is no longer only whether a given threat group uses AI, but whether offensive AI functions are being modularized, packaged, sold, rented, or embedded into service ecosystems in ways that lower barriers to operational autonomy.

ENISA’s 2025 threat assessment indicates that the ecosystem has moved beyond opportunistic use of mainstream consumer models and into a phase where “stand-alone malicious AI systems” have begun to appear since the beginning of 2025, a development it explicitly characterizes as of particular concern (1). ENISA also notes that threat groups have been observed using both commercial LLMs and diverted or jailbroken systems such as WormGPT, EscapeGPT, and FraudGPT to automate social engineering and speed malicious tool development (1). This is

strategically significant because commercialization does not require a single “autonomous cyber weapon” to dominate the landscape; it requires a set of interoperable products and services that collectively produce machine-scaled offensive outcomes.

The commercialization dynamic is best understood through **unbundling**. In earlier cybercrime markets, payload development, hosting, access brokerage, monetization, and laundering became separable roles. AI-enabled offensive capability is following a comparable trajectory, but the separable modules are different: prompt engineering for deception, local model deployment, browser and UI control, multilingual persona generation, code revision, target prioritization, and dynamic infrastructure management. Each of these functions can be offered independently. A phishing service no longer needs to provide exploit code if it can provide highly personalized spearphishing at machine scale; an intrusion operator no longer needs a fully autonomous malware platform if an agent can continuously rewrite scripts, test execution paths, or impersonate victims across business workflows.

One important implication is that the underground economy is shifting from **tool ownership** toward **orchestrated capability access**. Criminal and state-aligned operators increasingly obtain advantage not by building foundational AI models, but by combining open-weight models, browser automation, retrieval pipelines, cloud GPUs, stolen accounts, and task-specific wrappers. This is one reason the emergence of self-hosted malicious AI matters more than sensational labels. ENISA’s observation that actors may be moving “beyond jailbreaks towards customised tools running on local servers to avoid detection” points directly to a maturing supply chain in which hosting, model tuning, operational logging control, and OPSEC become integrated commercial offerings ([1](#)).

A useful analytical distinction is between **three commercialization tiers**.

Tier	Commercial form	Typical buyers/ users	Offensive value	Visibility to defenders
Tier 1	Commodity AI abuse of legitimate services	Broad criminal actors, fraud crews, low-mid sophistication operators	Cheap scale for phishing, impersonation, lures, scripting	Moderate, because providers may log use and enforce policy
Tier 2	Gray-market or diverted offensive wrappers around	Phishing specialists, access brokers, extortion affiliates,	Better task fit, fewer safeguards, multilingual	Lower, especially where tooling is self-hosted

Tier	Commercial form	Typical buyers/users	Offensive value	Visibility to defenders
	public/open models	covert state contractors	automation, reusable playbooks	
Tier 3	Stand-alone malicious AI systems and integrated agentic platforms	Higher-end criminal enterprises, state-linked operators, specialized service vendors	Closed-loop adaptation, local inference, lower policy exposure, campaign persistence	Low, especially if deployed on private infrastructure

The commercial transition from Tier 1 to Tier 3 is visible in several trends in the source material. First, ENISA records the routine use of AI to support phishing, deepfakes, and malware development, as well as the appearance of named malicious LLM derivatives (1). Second, the UK NCSC warns that keeping pace with “frontier AI-cyber developments” will be critical because AI will almost certainly generate resilience challenges through 2027 and beyond, including increased attack volume, expanded attack surface, and rapid capability proliferation (2). Third, commercial commentary from the enterprise security sector points to a structural shift from static chat interfaces to autonomous agents capable of executing actions across enterprise environments, which radically enlarges the attack surface where those systems are compromised, misdirected, or repurposed (3).

What is newly important for CTI is that **commercialization changes attribution economics**. When multiple unrelated actors rely on the same underlying agent wrapper, browser automation package, synthetic identity service, or local inference stack, visible tradecraft begins to converge. This weakens the utility of actor-centric heuristics and increases the importance of supply-chain intelligence on tools, inference hosts, model checkpoints, plugin frameworks, affiliate panels, reseller channels, and community support forums. In practical terms, defenders may increasingly confront distinct campaigns that look tactically similar not because the same actor is responsible, but because the same commercial substrate is being reused.

The market is also benefiting from demand-side pull. ENISA reports that by early 2025, AI-supported phishing represented more than 80% of observed social engineering activity worldwide (1). Even allowing for methodological variance across reporting, a proportion at that scale fundamentally alters incentives. Once AI-assisted social engineering becomes the dominant observed mode, vendors have a clear reason to specialize in adjacent functions: lead enrichment, persona maintenance, call scripting, multilingual localization, callback fraud support, and response triage. This is how markets deepen: not through one dramatic innovation, but through optimization around the most profitable step in the value chain.

The result is a new offensive stack in which “AI-enabled capability” should be treated less as a feature than as an **economic layer**. The commercial ecosystem now spans:

- model access and hosting,
- maliciously tuned or safety-reduced model variants,
- attack workflow orchestrators,
- synthetic content generation services,
- agentic browser and API execution frameworks,
- criminal customer relationship support,
- infrastructure provisioning and rotation,
- post-compromise analysis assistants,
- and training or documentation communities for operators.

The strategic effect is to democratize portions of offensive autonomy without equalizing all capability. Advanced exploit development, clandestine operations, and precision espionage still demand high sophistication. But social engineering, environment navigation, victim interaction, and workflow abuse are increasingly purchasable. That lowers the floor for capable intrusion behavior even if it does not eliminate the ceiling that separates elite actors from commodity crime.

A second-order consequence is that commercialization increases **operational redundancy**. If one provider disables accounts or one model host improves moderation, operators can shift to open models, local inference, or alternative wrappers. This is analogous to the evolution of botnet and hosting markets: resilience emerges not from technical perfection but from supplier diversity. The more modular the offensive AI economy becomes, the harder it is to disrupt through isolated takedowns.

This maturing ecosystem can be represented as a chain of specialized functions rather than monolithic products.

Commercial node	Typical capability sold or bundled	Relevance to autonomous operations	Likely customer segment
Model access brokers	Accounts, API credits, proxy access, stolen subscriptions	Enables scale and experimentation	Commodity fraud, low-tier crews
Malicious model wrappers	Safety-reduced prompting layers,	Improves offensive reliability and reduces user skill needs	Mid-tier criminals, phishing operators

Commercial node	Typical capability sold or bundled	Relevance to autonomous operations	Likely customer segment
	templates, prompt libraries		
Local inference packages	Self-hosted checkpoints, GPU deployment kits, logging control	Reduces provider visibility and moderation friction	Higher-end operators, state-linked units
Agent runners	Browser automation, tool use, workflow chaining	Converts content generation into executable tradecraft	Intrusion teams, IABs, extortion crews
Synthetic identity services	Fake profiles, multilingual bios, avatar generation	Supports long-lived social engineering and insider pretexting	Espionage, employment fraud, BEC actors
AI lure ecosystems	Fake AI software installers, clone sites, sponsored ad abuse	Exploits demand for AI tools as initial access vector	Malware distributors, credential thieves
Post-compromise copilots	Script repair, query generation, evidence triage	Accelerates lateral movement and data selection	Human-led intrusions with semi-autonomous support

The “AI lure ecosystem” merits emphasis because it demonstrates commercialization from the victimization side. ENISA documents multiple fraudulent websites impersonating legitimate AI tools such as Kling AI, Luma AI, Canva Dream Lab, and DeepSeek-R1 to deliver malware, along with malware and ransomware masquerading as AI tool installers ([1](#)). These campaigns show that AI commercialization is reflexive: attackers sell or distribute malicious capabilities **through the branding halo of legitimate AI adoption**. In effect, the demand for productivity and creativity tools creates a parallel criminal distribution market.

Commercialization also changes **time-to-abuse**. Because AI wrappers can be rapidly cloned and repackaged, the interval between a successful lure format or agentic workflow appearing in one campaign and being replicated by other actors is shrinking. The offensive diffusion cycle more closely resembles SaaS feature replication than traditional malware lineage. For CTI programs, this means monitoring should extend beyond malware families and C2 infrastructure to include

adversary experimentation with prompt libraries, browser automation scripts, open-source agent frameworks, and fake-AI brand impersonation campaigns.

Finally, the market is beginning to produce its own reputational and trust mechanisms. Historically, cybercrime markets relied on escrow, vouching, leak proofs, customer support, and affiliate reputation. AI-enabled offensive services will likely follow the same path, but with performance metrics such as phishing conversion rates, persona persistence, language quality, bypass reliability, and task success in browser workflows. As these performance metrics become standardized, offensive AI will become easier to benchmark, compare, and outsource. That is how a fragmented experimental space becomes a durable criminal industry.

State, Proxy, and Criminal Buyers: How Different Ecosystems Consume Commercial AI Offense

This section differs from earlier coverage of “adoption patterns” by focusing not on broad actor categories in the abstract, but on **procurement logic and consumption behavior**: how different threat ecosystems acquire, integrate, and operationalize commercial or quasi-commercial AI-enabled capabilities. The core issue is that actors with very different missions increasingly draw from overlapping AI supply channels, yet they consume those capabilities in distinct ways.

ENISA provides concrete evidence that China-nexus, Iran-nexus, and DPRK-nexus intrusion sets have used AI solutions including Google Gemini and OpenAI’s ChatGPT, primarily as research assistants, for productivity enhancement, and for reconnaissance and anomaly-detection evasion (1). It further notes that Famous Chollima used AI to generate convincing LinkedIn profiles and support communications with victim organizations (1). These examples are instructive because they show state-linked operators acting as **consumers of commercially available AI functions**, not necessarily as builders of unique sovereign AI offensive platforms. That consumption pattern matters: if state-linked actors can achieve operational value through mainstream or repurposed commercial systems, the threshold for rapid scaling is lower than if every actor had to build bespoke capability.

The demand characteristics of the three main consumer blocs—state services, state-aligned proxies, and profit-motivated crime—differ sharply.

Consumer bloc	Primary mission	Preferred AI-enabled purchases or integrations	Tolerance for opacity	Desired features
State intelligence/security services	Espionage, influence, pre-positioning, strategic access	Local models, covert research assistants, translation, persona generation, anomaly evasion support	Low tolerance for externally logged services in sensitive ops	OPSEC, customization, persistence, multilingual precision
State-aligned proxies and deniable fronts	Influence, harassment, disruptive operations, blended info/cyber effects	Deepfake tooling, phishing kits, social amplification agents, fake persona services	Moderate; may accept noisy tools if deniability remains	Speed, scale, plausible personas, narrative adaptation
Criminal enterprises	Revenue generation, access resale, fraud, extortion	Lead scoring, phishing automation, fake AI lure kits, browser agents, script copilots	Higher tolerance if conversion rates are high	ROI, ease of use, support, low cost, modularity

For **state services**, procurement tends to prioritize secrecy, customization, and control of telemetry. ENISA’s finding that malicious AI systems may be moving onto local servers to avoid detection is especially relevant here (1). A state service can tolerate substantial engineering overhead if the resulting platform minimizes exposure to provider logging, moderation, or legal process. Consequently, state consumption often focuses on local deployment, compartmented task modules, and integration with existing clandestine infrastructure. The AI need not perform every operational step; it must reliably accelerate the parts of the mission that benefit from machine speed and language flexibility, such as document triage, multilingual correspondence, rapid pretext generation, or support to long-running social engineering.

For **state-aligned proxies**, the calculus differs. These actors benefit from ambiguity and disposable operations. They are more likely to use commercially available or semi-commercial AI products directly, especially for influence activity, harassment at scale, mass messaging, or low-cost credential theft. They may not need the same level of OPSEC discipline because the value of

deniability can rest on volume and confusion rather than technical subtlety. If a campaign burns an account or platform, replacement is often acceptable. Their procurement logic therefore favors high-throughput content generation, persona factories, synthetic media, and automation that can bridge cyber intrusion with information manipulation.

For **criminal enterprises**, the key variable is return on investment. A ransomware affiliate or access broker is unlikely to prioritize custom local model hosting unless it materially improves conversion or lowers disruption risk. Instead, the criminal buyer prefers platforms that collapse specialist labor into repeatable workflows: generate personalized lures, sort responses, validate credentials, draft follow-up messages, produce malicious attachments or scripts, and maintain fake support interactions. ENISA's report that more than 80% of phishing emails identified in the referenced period used AI to some extent strongly suggests that this ROI case has already been made in the market (1).

The DPRK-linked employment and social engineering ecosystem is one of the clearest examples of differentiated consumption. Famous Chollima's use of AI-generated LinkedIn profiles demonstrates that the actor's challenge is not merely writing English-language lures but sustaining **credible, long-duration synthetic professional identities** (1). That demand encourages a supply market for profile text generation, avatar enhancement, résumé tailoring, communication assistance, and perhaps eventually interview copilots or behavior simulators. This is distinct from commodity phishing: the buyer needs continuity, memory, and persona coherence over time, not just one high-conversion message.

China-nexus consumers appear to derive value from AI as a research and productivity assistant in service of broader espionage operations, according to ENISA (1). This consumption model aligns with a wider state preference for using AI to compress analyst time, support reconnaissance, process open-source data, and help evade detection through more adaptive operational planning. In procurement terms, these users may favor tools that integrate with analyst workflows and can be compartmented for mission-specific use. Their value proposition is not necessarily full autonomy but **reduction in cognitive and linguistic bottlenecks**.

Iran-nexus and proxy ecosystems likely derive disproportionate advantage from AI capabilities that strengthen multilingual messaging, thematic agility, and mass targeting. Where campaign goals include intimidation, influence, credential theft, or disruptive nuisance operations, the most commercially attractive features are not stealthy malware innovation but **fast narrative localization** and scalable interaction. Commercial AI tools, especially when stripped of safeguards or self-hosted, fit that need well.

A deeper implication is that commercial AI capability is creating a **shared tooling zone** across adversary classes. Historically, the overlap between espionage tools and commodity criminal tools existed but was limited by engineering complexity and mission specificity. AI services change that. The same underlying language model or browser automation framework can support a DPRK employment fraud campaign, a BEC actor's multilingual correspondence, and a state proxy's influence personas. Mission goals differ, but the procurement substrate converges.

This convergence creates three CTI challenges:

1. **Attribution dilution:** identical or similar AI-generated stylistic artifacts may reflect common tool access rather than common operator identity.
2. **Faster horizontal diffusion:** once one actor demonstrates a profitable AI-enabled tactic, vendors can adapt it rapidly for other customer segments.
3. **Mixed ecosystems:** legitimate AI vendors, gray-market resellers, and criminal wrappers can all contribute to the same operational chain.

The NCSC's warning that the commercial cyber intrusion sector will "almost certainly expand over the next five years" with state demand as a key driver is highly relevant here (2). AI-enabled offensive commercialization should therefore be viewed not as a crime-only phenomenon, but as part of a broader **cyber proliferation** environment in which states, contractors, proxies, and criminals draw from overlapping commercial innovation pools. The state role is especially important because state demand can stabilize markets that would otherwise remain niche. Where governments or state-linked entities fund experimentation, subsidize permissive hosting environments, or tolerate dual-use vendors, they effectively increase the supply of offensive AI capability available to less sophisticated actors.

Commercialization also changes the balance between **operators and intermediaries**. In traditional intrusion ecosystems, some actors developed high competence in-house because suitable outsourcing markets did not exist. As AI-enabled services mature, more actors can remain strategically focused while outsourcing linguistics, content production, persona management, preliminary target research, or even workflow automation. This means groups that were once constrained by language barriers, limited analyst capacity, or lack of reliable social engineering talent can now buy their way around those weaknesses.

The following matrix captures differences in consumption behavior.

Operational requirement	State service consumption style	Proxy consumption style	Criminal consumption style
Long-term persona building	Highly curated, often integrated with HUMINT-style targeting	Disposable but convincing personas for bursts of activity	Used where BEC, fraud, or job scams require trust-building
Reconnaissance support	Structured, analyst-assistive, often local or compartmented	Opportunistic, fast-turn, target list generation	Lead enrichment for conversion optimization
Content generation	High quality, multilingual, mission-tailored	Narrative-reactive, mass-message capable	Conversion-focused, A/B tested, automated
Workflow execution	Cautious integration with existing tradecraft	Use where speed matters more than subtlety	Adopt if it shortens time to cash or access resale
OPSEC preference	Strong bias to local, deniable, minimally logged systems	Mixed; deniability often achieved through scale and proxies	Cost-sensitive, variable, improving over time

In effect, the AI offense market is not producing one universal customer profile. It is producing differentiated consumption models that map to mission needs. Yet the shared underlying tooling means that successful innovations can cross boundaries quickly. A criminally proven browser agent that improves account takeover at scale can be adapted for espionage collection in SaaS environments; a state-developed persona toolkit can inspire fraud services; a fake-AI installer lure effective for malware delivery can be copied by ransomware affiliates. Commercialization thus creates **cross-pollination without organizational merger**.

Interface Economies: Where Commercial Offensive AI Finds the Highest Return

Earlier sections in prior reports examined target environments susceptible to autonomous sequencing. This section is narrower and more market-oriented: it identifies the **specific environments and interfaces where commercialized AI-enabled offensive capability is economically most attractive**. The central question is not only where agents *can* operate, but where suppliers and buyers obtain the greatest return from automating or semi-automating attack behavior.

The highest-return interfaces in 2025–2026 share five traits: they are machine-readable, action-rich, common across organizations, difficult to perfectly harden, and amenable to language-mediated interaction. Commercial offensive AI does not need every target to be equally automatable; it only needs a set of environments where reusable playbooks generate disproportionate payoff.

1) Human communication surfaces as programmable intrusion terrain

ENISA reports that over 80% of observed social engineering activity worldwide by early 2025 involved AI-supported phishing (1). This statistic implies that email, messaging, voice, and professional networking interfaces are now the **primary commercial proving grounds** for offensive AI. These surfaces are attractive because language models are naturally suited to them, and because enterprise defenses often focus on binaries, signatures, or known indicators rather than on dynamically generated social context.

The commercial opportunity extends beyond email drafting. Suppliers can sell:

- target-specific pretext generation,
- follow-up response handling,
- multilingual adaptation,
- fake recruiter or vendor personas,
- voicemail and vishing scripts,
- attachment naming optimization,
- and engagement scoring based on reply behavior.

The value of these offerings is cumulative. Instead of one phishing email, a commercial service can manage an entire conversational funnel. This is especially powerful against enterprise users accustomed to asynchronous business communication where polished language and sustained back-and-forth are normal.

2) AI application trust channels and software distribution touchpoints

ENISA's documentation of fraudulent websites impersonating legitimate AI tools and malware masquerading as AI tool installers shows that **AI adoption itself has become an attack interface** (1). This is commercially attractive because user demand for AI software is high, trust cues are poorly understood, and many organizations permit experimentation with new AI-related tools. Attackers are monetizing this demand through clone sites, sponsored-ad abuse, trojanized installers, and fake update mechanisms.

This interface economy is particularly important because it blends **brand impersonation** with **supply-chain style delivery**. A commercial malware distributor no longer has to invent a fictitious

product; it can impersonate a fashionable AI tool that victims are already searching for. The supply-side cost is low, while the victim-side curiosity is high. In CTI terms, this creates a recurring pattern: as soon as a new popular AI service or local model distribution gains visibility, criminal operators can generate a parallel ecosystem of spoofed installers, fake login pages, and bundled malware loaders.

3) Hosted machine learning and developer package ecosystems

The source set also includes reporting on attacks against hosted ML models, code agents, and package ecosystems, including abuse paths involving PyPI, code-assistant ecosystems, and slopsquatting-like supply-chain risks (1). These environments are commercially valuable because they sit at the intersection of developer trust, automation, and code execution. Commercial offensive AI can exploit them in several ways:

- generating convincing malicious packages,
- producing typosquat or hallucination-targeted package names,
- creating realistic README files and release notes,
- assisting in dependency poisoning narratives,
- and steering code-generation assistants toward unsafe or attacker-controlled artifacts.

These are not merely “developer threats” in isolation. They matter because code-assistant and ML-hosting ecosystems can become **multipliers**: compromise one package or one model supply path and many downstream enterprises inherit exposure. For commercial offensive vendors, this offers a high-leverage business case, especially for customers seeking scalable access rather than bespoke exploitation.

4) Autonomous enterprise agents and agentic middleware

CSO reporting on the “agentic AI boom” highlights a rapid enterprise shift toward autonomous agents as organizations move beyond static RAG deployments (3). For adversaries, enterprise agents are attractive interfaces for two reasons. First, they aggregate permissions and actions. Second, they often mediate workflows through natural language, making them vulnerable to instruction injection, tool abuse, context poisoning, and unauthorized action execution.

The commercial offensive opportunity is not limited to compromising the agent model itself. Vendors can sell:

- prompt injection frameworks,
- agent-targeting reconnaissance templates,
- exploit content for retrieved documents,

- poisoned knowledge artifacts,
- malicious browser session steering,
- and workflow-disruption kits that exploit agent trust boundaries.

This is becoming a distinct interface economy because the spread of enterprise agents standardizes a new class of reachable actions: reading and sending messages, summarizing documents, browsing internal portals, scheduling tasks, querying systems, and invoking plugins. Each exposed action becomes a candidate for commercialization.

5) Defensive AI pipelines as attack targets

As enterprises increasingly use AI in the SOC and DDI environments, adversaries gain incentives to target the **AI-assisted defense stack** itself. CSO notes adversarial AI risks such as evasion and data poisoning against defensive systems (4). Commercial offensive AI can profit here by helping customers mutate indicators, reshape command-and-control patterns, or contaminate training and detection datasets. This is attractive because impairing the defender’s AI can produce leverage across multiple controls simultaneously.

The interface economy around defensive AI is less mature than phishing or fake-tool lures, but it may become strategically important. As more blue teams depend on AI-generated triage and automated recommendations, attackers will increasingly seek to exploit the decision inputs that those systems trust. Commercial services that tune malicious behavior to remain below AI detection thresholds may eventually become as common as crypters once were in malware markets.

The economically most attractive interfaces can be compared as follows.

Interface category	Why commercial AI offense performs well here	Typical offensive service format	Enterprise impact
Email, chat, social messaging	Language generation and response handling are highly reusable	Subscription phishing copilots, persona bots, response agents	Credential theft, fraud, access brokering
AI-brand software distribution	High user demand and low verification discipline	Fake installers, clone sites, malvertising kits	Malware delivery, credential capture, ransomware staging
Package/model ecosystems			

Interface category	Why commercial AI offense performs well here	Typical offensive service format	Enterprise impact
	Trust is delegated to repositories and assistant outputs	Malicious package generation, slopsquatting, poisoned model artifacts	Supply-chain compromise, code execution
Enterprise agent platforms	Rich permissions and natural-language control pathways	Prompt injection kits, poisoning content, workflow abuse modules	Unauthorized actions, internal data exposure
Defensive AI systems	Adversarial tuning can degrade multiple controls at once	Evasion packs, poisoning support, traffic mutation services	Reduced detection efficacy, alert confusion

A notable strategic point is that these target interfaces are not chosen primarily for technical novelty. They are chosen because they produce **repeatable economic return**. Offensive AI commercialization thrives where workflows are common across many victims, where trust is routine, and where natural-language interaction masks malicious intent. This explains why socially mediated and AI-mediated interfaces now occupy such a central place in the threat landscape.

The economics also favor **hybrid deployment**. A threat actor may use AI for one interface stage and conventional tooling for another. For example, AI may optimize lure creation and conversation handling, while commodity stealers or remote management tools execute post-compromise tasks. That modularity means defenders cannot infer low risk merely because they do not observe fully autonomous end-to-end attacks. Commercial offensive AI can radically improve attacker outcomes even when embedded in only one or two stages of the kill chain.

Finally, interface-focused commercialization accelerates organizational asymmetry. Enterprises must secure each new AI-facing surface, validate third-party AI tools, govern internal agents, and harden software supply chains. Attackers only need to identify which of those surfaces is most weakly controlled and most easily automated. Commercial providers can then package that weak point into a reusable service. This is why the offense-defense balance is shifting: automation concentrates on the attacker's highest-yield steps, while the defender must secure the full spectrum of possible interfaces.

Case Studies in Emerging Offensive AI Tradecraft: What the Field Evidence Actually Shows

This section focuses on **real-world evidentiary patterns** rather than theoretical potential. It differs from earlier architectural discussion by emphasizing concrete observed or reported use cases that illuminate how commercialization and actor ecosystems are already altering operations. The evidence still points to uneven adoption rather than ubiquitous full autonomy, but the cases are operationally significant because they reveal where machine assistance is already producing measurable attacker advantage.

Case Study A: AI-supported social engineering at majority scale

ENISA's assessment that by early 2025 AI-supported phishing campaigns reportedly represented more than 80% of observed social engineering activity worldwide is one of the most consequential data points in the current landscape ([1](#)). Even if one interprets the figure conservatively as reflecting broad "AI involvement" rather than fully machine-run campaigns, the implication is clear: AI has become normalized in the most common initial access and fraud channel. Commercialization follows prevalence. Once a capability underpins the majority of observed activity in a domain, suppliers emerge to optimize quality, localization, persistence, and evasion.

Operationally, this means that the baseline threat to enterprises is no longer poorly written mass phishing. It is **adaptive, context-aware, often multilingual communication** that can be revised instantly based on target profile or response. A commercial service selling such functionality does not need deep technical sophistication; it needs conversion advantage. That makes the market broad, stable, and resilient.

Case Study B: Famous Chollima and AI-generated professional personas

ENISA reports that Famous Chollima used AI to generate convincing LinkedIn profiles and support communications with victim organizations ([1](#)). This case is important because it demonstrates AI value not merely in initial contact, but in **identity fabrication and sustained interaction**. The threat here is not a single prompt-generated message; it is a maintained synthetic presence designed to survive scrutiny in professional ecosystems.

The offensive innovation lies in shifting from "content generation" to **persona lifecycle management**:

- crafting biographies aligned to industries and job roles,
- generating coherent work histories,
- sustaining tone across exchanges,

- tailoring replies to specific recruiters or partners,
- and reducing linguistic or cultural cues that would otherwise expose the operator.

This is a highly commercializable capability. A provider could package profile generation, language polishing, avatar support, and communication templates into a subscription model for actors conducting employment fraud, insider access attempts, vendor impersonation, or BEC. The case therefore illustrates how state-linked tradecraft can migrate into broader criminal service markets.

Case Study C: Stand-alone malicious AI systems and the move to self-hosted offense

ENISA identifies the emergence of allegedly stand-alone malicious AI systems over the prior two quarters, citing examples such as Xanthorox AI and describing this as a likely indicator that threat groups are moving beyond jailbreaks toward customized tools running on local servers ([1](#)). The significance of this development is not only technical but commercial. Self-hosted malicious AI enables:

- reduced dependency on commercial provider controls,
- improved OPSEC,
- custom tuning to preferred workflows,
- lower interruption risk from account bans,
- and easier integration with criminal orchestration stacks.

From a field evidence standpoint, the rise of such systems suggests that the market is entering a phase similar to the migration from public crypters and open botnets to private loaders and bespoke panels. Once local deployment becomes practical, higher-end users gain a strong incentive to internalize or semi-internalize AI capability. That does not eliminate commercialization; rather, it shifts value toward installers, wrappers, deployment services, tuning assistance, and support communities.

Case Study D: Fake AI tool ecosystems as malware and ransomware distribution channels

ENISA documents multiple cases in which fraudulent websites imitating legitimate AI brands such as Kling AI, Luma AI, Canva Dream Lab, and DeepSeek-R1 were used to distribute malware, and also notes ransomware and malware disguised as AI tool installers ([1](#)). This case family is important because it shows commercialization in a very mature form: **brand hijacking + malware delivery + search demand capture**.

These campaigns are strategically revealing for several reasons:

1. They exploit the social legitimacy of AI adoption.

2. They are reusable across many brands and victims.
3. They can be operated by actors with limited bespoke intrusion skill.
4. They convert hype around AI into a scalable distribution mechanism.

This is classic crimeware market behavior adapted to the AI era. As new AI products gain visibility, attackers can quickly clone branding, spin up landing pages, buy ads, and bundle loaders. The speed of commercial replication here likely exceeds traditional software impersonation campaigns because AI products attract unusually high organic interest and rapid user experimentation.

Case Study E: Hosted ML model and code-agent targeting

The ENISA source list references reporting on malicious methods targeting hosted ML models, vulnerabilities affecting code agents such as GitHub Copilot and Cursor, slopsquatting enabled by AI hallucinations, and prompt- or retrieval-driven attack paths against AI systems ([1](#)). Collectively, these incidents point to an emerging operational reality: **the AI ecosystem itself is becoming both a target and an attack amplifier.**

The field evidence here is especially significant for enterprise defenders because it shows adversaries exploiting not just user trust, but **machine trust**. If code assistants can be manipulated toward unsafe packages or agentic tooling can be weaponized through prompt or context abuse, then attackers gain leverage over developer workflows and enterprise automation. This changes the balance of power by allowing relatively cheap adversarial inputs to influence high-trust automated or semi-automated processes.

Case Study F: Frontier risk recognition by national cyber authorities

The UK NCSC's 2025 Annual Review states that keeping pace with "frontier" AI-cyber developments will almost certainly be critical to cyber resilience for the decade to come, and that AI will almost certainly pose resilience challenges to 2027 and beyond through increased attack volume, expanded attack surface, and unpredictable proliferation of capability ([2](#)). While this is not a single incident, it is a high-value intelligence indicator. National cyber authorities do not typically elevate a risk domain in this language without seeing enough evidence to justify strategic prioritization.

For CTI purposes, this matters because it validates that the issue has moved beyond speculative research into the category of **anticipated operational impact**. When such authorities connect AI not merely to content quality but to systemic attack-surface expansion and capability proliferation, they are implicitly recognizing the commercialization and diffusion dynamic.

The case evidence can be synthesized comparatively.

Case	Observed pattern	What it reveals about commercialization	Implication for defenders
AI-supported phishing majority use	AI embedded in most observed social engineering activity	Market has matured beyond experimentation for phishing workflows	Language quality is no longer a reliable detection cue
Famous Chollima persona generation	AI sustains fake professional identities and communications	Persona management is becoming a purchasable capability	Trust workflows in recruiting and partner engagement are at risk
Stand-alone malicious AI systems	Shift toward self-hosted customized offensive AI	Vendors can support private deployment and tuning markets	Provider-side safety controls are an insufficient defense layer
Fake AI installer campaigns	AI brand impersonation used for malware/ ransomware delivery	Demand for AI tools creates a durable lure economy	Enterprise software governance must include AI-specific trust controls
Hosted ML/ code-agent targeting	AI ecosystems targeted as both attack path and multiplier	Offensive services can monetize machine-trust abuse	Developer and agentic environments become high-priority CT

Primary Target Environments, Identities, Cloud Interfaces, and AI Agent Surfaces Under Attack

Identity Persistence Fabric: Token Abuse, OAuth Delegation, and Non-Human Privilege Chains

While earlier sections addressed identity systems and authentication workflows as broad attack terrain, this section is narrower: it focuses specifically on the *persistence-enabling identity substrates* that autonomous and semi-autonomous adversarial systems can exploit after or alongside initial access. The distinction matters. The earlier material emphasized where machine-driven attacks gain leverage; the present analysis isolates *which identity artifacts and delegation paths* now function as durable control channels for offensive AI operations.

The most important shift in 2025–2026 is that identities are no longer attacked only as login events or credential objects. They are increasingly treated by attackers as programmable trust containers: bearer tokens, delegated OAuth grants, application consents, service principals, workload identities, and secret retrieval relationships that can be discovered, scored, and re-used by machine-guided tradecraft. Microsoft’s 2025 threat reporting is especially notable here because it documents a measurable rise in identity-centered pressure: in the first half of 2025, identity-based attacks rose by **32%** (1). For the purposes of adversarial automation, that figure is not merely a trend indicator; it is evidence that identity has become one of the highest-yield operational environments for scalable intrusion logic.

A critical reason is that delegated trust is easier for a machine to preserve than human access. Passwords expire, users notice prompts, and endpoint implants create detection opportunities. By contrast, OAuth grants, application consents, refresh-capable sessions, and service-linked tokens can remain valid across password resets and often survive the remediation steps defenders still reflexively prioritize. Microsoft explicitly notes that app consent phishing can trick users into granting malicious applications OAuth permissions, thereby bypassing MFA and persisting beyond password resets (1). That property makes these grants ideal footholds for autonomous operators: they are machine-usable, scriptable, and often less visible than malware or repeated interactive logons.

This has direct implications for adversarial AI. Agentic systems excel when they can evaluate alternative routes to the same objective, compare privilege outcomes, and retain context across a sequence of permission-dependent actions. In identity environments, this means the system can move from one form of delegated authority to another rather than repeatedly re-solving the initial access problem. For example, an agent that encounters phishing-resistant MFA may redirect toward app consent abuse; if direct user compromise is noisy or blocked, it may pivot to workload identities or secret-bearing applications; if a stolen session is short-lived, it may search for app registrations or service principals whose effective privileges exceed their visibility. The point is not that AI “breaks” identity controls by itself, but that identity ecosystems contain enough alternate trust channels to reward adaptive, search-driven offensive behavior.

Microsoft’s 2025 reporting highlights several such channels in one threat pattern: layered attacks that combine **device code phishing** and **OAuth consent phishing**, sometimes with redirection to **adversary-in-the-middle (AiTM)** sites (1). This combination is operationally significant because each mechanism serves a different function in the access lifecycle. Device code abuse exploits a legitimate authentication flow intended for constrained-input devices. OAuth consent abuse harvests durable delegated access. AiTM infrastructure can capture live session material or proxy trust exchanges. Used together, they create a layered acquisition and persistence model well-suited to

partial automation. An offensive agent can test which path yields the best mix of privilege, stealth, and durability, then continue from the most successful branch.

Why workload identities are especially exposed

One of the clearest empirical shifts in the source material is the pivot from human users to workloads. Microsoft states that as phishing-resistant MFA and conditional access strengthen end-user defenses, attackers are increasingly turning to **workload identities—apps, services, and scripts that access cloud resources**—because these non-human identities often carry elevated privileges yet lack equivalent security controls (1). This is directly relevant to adversarial machines because workload identities are better suited to machine-speed abuse than human accounts are.

A human identity often involves behavioral variability, interactive prompts, and a social-detection risk. A workload identity, by contrast, is designed for automation. It exposes predictable permission scopes, deterministic API interactions, stable naming, and often long-lived secrets or trust relationships. For an attacker using autonomous logic, this creates an environment in which graph exploration becomes practical: enumerate applications; identify those with access to storage, messaging, secrets, or management APIs; test whether delegated permissions can be converted into application-level persistence; examine whether a compromised app can retrieve material from a secrets store; and assess whether that store unlocks still more identities.

Microsoft specifically points to **Key Vault pivoting** as a concern: compromising apps with access to secrets can enable lateral movement and privilege escalation, often without immediate detection (1). This is not merely a cloud hygiene issue. It is a machine-plannable expansion path. If an autonomous system can identify an application identity with rights to query a secret repository, then retrieve credentials or keys, it can recursively widen its options. In graph terms, the application becomes an intermediate node between one trust domain and another. In operational terms, the attacker no longer needs a new exploit—only the capacity to reason over permission relationships and selectively invoke legitimate APIs.

Identity artifacts now preferred by adaptive adversaries

The following table isolates the identity-linked artifacts and interfaces most relevant to autonomous offensive operations based on the current reporting.

Identity target element	Why it attracts adversarial automation	Operational effect if abused	Evidence in current reporting
OAuth consent grants	Stable delegated permissions; bypasses password-focused remediation	Durable access to user data and resources without re-authentication pressure	Microsoft reports app consent phishing that bypasses MFA and persists past password resets (1)
Device code authentication flows	Legitimate protocol can be socially manipulated and machine-assisted	Session establishment under valid auth pathways	Microsoft identifies evolving device code phishing in cloud identity abuse (1)
Session tokens proxied through AiTM	Immediate access and policy bypass opportunities	Account compromise, lateral phishing, access continuity	Microsoft notes layered attacks combining device code, OAuth, and AiTM (1)
Workload identities / service principals	Automation-native, elevated privileges, often weak governance	Cloud resource access, secret retrieval, stealthy persistence	Microsoft says attackers are pivoting to non-human identities as user defenses improve (1)
Secret store access paths	Enables recursive discovery of new credentials and permissions	Lateral movement and privilege escalation	Microsoft describes Key Vault pivoting through compromised apps (1)
Legacy authentication pathways	Older protocols can weaken modern policy assumptions	Covert access and policy evasion	Microsoft identifies abuse of legacy authentication in cloud identity attacks (1)

What is especially important is the *composability* of these artifacts. An adversarial machine does not need one perfect foothold if it can chain several imperfect ones. A user can be tricked into granting OAuth consent; the resulting permissions reveal application relationships; a compromised application can reach a secret store; that secret store may expose credentials for another workload;

and that workload may hold broader management-plane rights than the original user ever had. This is exactly the kind of environment in which autonomous planning has disproportionate value: the attacker is not manually improvising each pivot but evaluating a searchable permission graph.

Internal phishing and identity-enabled expansion

Microsoft also notes that compromised identities are being used for **internal phishing and lateral movement** (1). This is important because it demonstrates that identity abuse is no longer just an entry condition; it is also a propagation medium. Once an adversary obtains a valid identity foothold, especially one with mail or collaboration platform access, the account can be used to expand trust inward. In an agentic campaign, this becomes a natural next step: the machine can mine prior conversations, identify plausible contacts, tailor follow-on lures, and determine which additional identities are likely to approve requests, open links, or authorize application access.

This is one of the clearest ways that AI changes the defender–attacker balance inside identity environments. Historically, lateral expansion through internal trust required labor: reading correspondence, choosing believable pretexts, and staging messages in context. Language-capable systems compress that labor. Microsoft’s observation that the escalation in identity attacks may reflect adversaries’ increasing use of AI to craft highly convincing social engineering lures is therefore highly relevant (1). Once an initial account exists, offensive AI can turn enterprise communication history into a map of trust relationships.

Identity defense implications specific to adversarial machines

Microsoft’s recommended countermeasures—app governance, conditional access, and continuous token monitoring—are not generic best practices in this context; they are direct responses to machine-usable attack persistence (1). Traditional credential-centric response models assume the attacker’s primary object is the password or account. But the sources indicate the operative object is increasingly *delegated authority*, especially when embodied in artifacts that can be consumed non-interactively.

For that reason, the most exposed identity environments are not simply “those with users.” They are those with the following characteristics:

1. **High density of delegated permissions**
2. **Weak inventory of apps and service principals**
3. **Secret stores linked to application identities**
4. **Legacy auth compatibility or policy exceptions**
5. **Low-visibility token issuance and consent events**

These characteristics describe a trust topology that autonomous systems can navigate more effectively than legacy scripted intrusions. The machine's advantage is not brute force but combinatorial reasoning over access pathways.

Cloud Resource Graphs and Secret-Bearing Services as Autonomous Pivot Terrain

Where previous report sections treated cloud control planes and SaaS administration as high-leverage targets in general terms, this section focuses on a more specific problem set: how autonomous and semi-autonomous adversaries exploit *resource dependency structure* inside cloud estates. Rather than re-covering cloud consoles or broad administrative abuse, the emphasis here is on graph-like relationships among applications, secrets, data stores, and permissions that create fertile terrain for machine-directed expansion.

Modern cloud intrusions increasingly reward attackers who can reason over topology rather than simply execute a fixed checklist. The sources supplied for this report indicate that cloud identity systems are now a primary target for attackers seeking **persistent, covert access**, with malicious OAuth apps, legacy authentication abuse, device code phishing, and AiTM techniques all contributing to long-term access and exfiltration without triggering alerts ([1](#)). Yet the strategic significance lies beyond the initial compromise. Once inside, the cloud becomes a dependency graph: storage accounts, vaults, service connections, automation identities, scripts, and trust bindings. That graph is unusually compatible with autonomous exploration.

Cloud platforms expose machine-readable metadata, named resources, role assignments, and API-reachable services. This makes them ideal for an attacker that can ingest feedback, compare paths, and seek the least-resisted route to a campaign objective. Human operators can and do perform this work manually, but AI-enabled systems reduce the cost of understanding heterogeneous documentation, translating policy names into likely capabilities, and preserving state as the attack traverses services. This is especially consequential in sprawling environments where no single administrator fully understands all inherited or chained permissions.

Secret-centered lateral movement

Among the most consequential observations in Microsoft's 2025 report is the prominence of **Key Vault pivoting** through compromised apps that possess access to secrets ([1](#)). This deserves separate treatment because it illustrates a shift from endpoint-centric lateral movement to *secret-mediated* lateral movement.

Traditional lateral movement often depends on host compromise, credential dumping, or remote execution. In cloud-native environments, the equivalent operation may be accomplished by acquiring a workload identity that can read an API key, signing credential, certificate, or connection string from a secret repository. Once that material is obtained, the attacker can reach new resources under apparently legitimate conditions. For an autonomous system, this is attractive because every step can be represented as a queryable state change:

- Which applications have vault access?
- Which secrets correspond to higher-privilege identities?
- Which identities unlock additional storage, messaging, automation, or management APIs?
- Which branch yields the greatest payoff with the lowest telemetry footprint?

This logic transforms secret stores from passive repositories into strategic relay points. The vault is not just a target; it is a map fragment. If the machine can associate secret names, applications, and role bindings, it can infer the structure of the enterprise's implicit trust model.

Why cloud graphs are favorable to adversarial AI

Autonomous offensive systems perform best where state is explicit and reversibility is high. Cloud environments often satisfy both conditions. APIs return structured errors, role assignments are enumerable, object names reveal business functions, and many actions are reversible or testable in low-volume ways. An attacker can attempt a query, inspect the response, infer capability boundaries, and then refine its plan. This iterative loop is exactly the type of machine reasoning that becomes more effective as environments become more self-describing.

The sources do not provide a single numerical estimate for “AI-driven cloud expansion events,” but they do provide enough evidence to infer why cloud estates are rising in offensive value. Microsoft reports increasing cloud identity abuse and emphasizes the need for **continuous token monitoring** and **app governance** in response ([1](#)). Those prescriptions make sense only because cloud abuse now frequently occurs through legitimate control surfaces rather than overt malware. The machine-readable quality of cloud systems gives autonomous adversaries leverage not because the APIs are insecure by default, but because *trust relationships are discoverable and machine-actionable at scale*.

Cloud target categories most exposed to machine-guided chaining

The following table frames cloud target categories not as administrative surfaces in the abstract, but as *pivot classes* for autonomous operations.

Cloud target class	Typical machine-readable clues	Why autonomous adversaries value it	Likely downstream opportunity
Secret repositories and key stores	Vault names, access policies, app associations, secret metadata	Centralized credential concentration; reveals hidden trust links	Credential expansion, app impersonation, key reuse
Application registrations and service principals	Permission scopes, app owners, delegated vs. application permissions	Maps non-human access and persistence options	Durable access, privilege inheritance, stealthy API use
Storage and document services	Container names, file metadata, indexability, owner tags	High-value data exposure with low malware requirement	Exfiltration, intelligence collection, extortion staging
Automation accounts / runbooks / scripts	Job definitions, linked identities, environment variables	Embedded operational knowledge and reusable execution context	Scheduled persistence, scripted recon, environment control
Messaging and collaboration APIs	Mailbox access scopes, conversation history, attachment access	Trust amplification and internal targeting	Internal phishing, fraud, business process manipulation
Tenant configuration and policy objects	Policy names, exceptions, role delegations	Identifies weak points and governance drift	Persistence, reduced logging visibility, privilege broadening

What distinguishes these categories is that they are not merely repositories of value; they are *decision support artifacts* for an attacker. A storage account can reveal project names; a vault can reveal application naming conventions; a mailbox can reveal approval workflows; an automation script can reveal hardcoded endpoints and environment assumptions. Autonomous systems can fuse these clues into an increasingly accurate internal model of the victim environment.

Long-term access without traditional malware footprint

Microsoft's characterization of these methods as enabling **long-term access and data exfiltration without triggering alerts** is central to understanding why cloud environments are becoming the preferred operating space for adversarial machines (1). Autonomous systems do not need custom implants if the environment already provides legitimate APIs for reading data, sending mail, enumerating resources, and changing application settings. In cloud environments, offensive adaptation often looks less like exploitation and more like selective overuse of native features.

This has strategic consequences for enterprise defense. Traditional incident response often assumes a meaningful boundary between “compromise” and “administration.” In cloud estates, especially those rich in service principals and delegated apps, that boundary weakens. The offensive machine's task is simply to identify which legitimate action sequence most closely approximates its objective while remaining beneath detection thresholds.

Resource graph exploitation and campaign economics

This is also where offensive AI changes the economics of cloud intrusion. Many cloud environments are too complex for small criminal crews to fully understand manually, especially under time pressure. AI-assisted exploration lowers the expertise threshold for navigating those environments. A semi-autonomous operator does not need to memorize every service dependency if the system can read role descriptions, infer likely meaning from naming conventions, and propose the next best action. This does not create “push-button” compromise, but it does compress the learning curve enough to widen the pool of actors who can exploit cloud complexity for operational gain.

The cumulative effect is that the most threatened cloud interfaces are not just administrative consoles already discussed elsewhere, but *resource relationship layers*: the secret-bearing applications, delegated service objects, automation identities, and data services that translate one foothold into many.

AI Agent Tooling, Protocol Mediation, and the New Attack Surface of Reasoning-Driven Execution

This section differs from the existing material on “autonomous enterprise agents and agentic middleware” by moving from market-oriented interface analysis to a more operational question: *which parts of the agent stack itself are emerging as primary attack surfaces when adversaries seek to hijack autonomous execution inside enterprises?* The focus here is not commercialization trends

or generic prompt injection risk, but the concrete surfaces through which AI agents select tools, ingest instructions, and translate language into action.

CrowdStrike's 2026 reporting is especially useful because it frames the problem with precision: **agentic tool chain attacks** target the **reasoning layer** where AI agents decide which tools to use and how to use them (2). This is a critical conceptual advance for CTI analysis. In traditional software security, the decisive attack surface is often code execution, protocol implementation, or memory safety. In agentic AI systems, the attack surface increasingly includes the *semantic control plane*—tool descriptions, schemas, examples, instructions, retrieved context, and metadata that influence planning.

That matters because agentic systems are being deployed with increasingly broad operational permissions. CrowdStrike notes that AI agents differ from traditional software in that they interpret prompts, form plans, select tools, and react to results in a continuous loop (2). Once such systems are connected to enterprise resources, natural-language and metadata channels become privileged pathways to action. The “interface” under attack is no longer only a UI, API, or shell—it is the machine's own decision substrate.

Tool descriptions and metadata as adversarial control points

CrowdStrike explicitly states that tool chain attacks manipulate the **language, metadata, and context** guiding an agent's decision-making process (2). This is operationally significant because many defenders still assume the agent's tools are safe if the underlying APIs are authenticated. But if the model decides which tool to invoke based on semantically interpreted descriptions, then tampering with those descriptions can redirect behavior even when the tool itself is not compromised in a classical sense.

For example, an agent may be told that a specific connector is the proper route for exporting a report, retrieving a file, updating a record, or checking a calendar. If adversarial content can bias the tool-selection layer—through poisoned examples, manipulative schema annotations, misleading plugin metadata, or injected context—the agent may still appear to operate normally while performing unauthorized actions. CrowdStrike emphasizes this exact risk: successful tool chain attacks can make agents seem normal while **secretly leaking data, executing unauthorized actions, or enabling lateral movement** (2).

From an offensive cyber perspective, this creates a new class of target environment: the agent orchestration layer. The attacker does not always need to compromise the endpoint or defeat core authentication if the agent already possesses the relevant authority. Instead, the adversary targets the inputs that shape the agent's action selection.

Protocol surfaces: MCP, A2A, and indirect instruction paths

Microsoft's 2025 defense report identifies one of the most pressing AI security challenges as **prompt manipulation attacks**, including direct and indirect prompt injections and exploitation via protocols such as **Model Context Protocol (MCP)** and **Agent2Agent (A2A)** (1). This is a crucial signal because it indicates that the attack surface is expanding from individual prompts to *inter-agent and context-sharing protocols*.

In practical terms, protocol-mediated AI environments create several exposure classes:

1. **Context ingestion surfaces** — the documents, files, chat histories, retrieved records, and memory objects an agent reads before acting.
2. **Tool invocation surfaces** — the schemas, descriptions, and examples that tell the model which action is appropriate.
3. **Inter-agent coordination surfaces** — the messages, delegated tasks, and planning exchanges between agents or agent-like services.
4. **Plugin or connector trust surfaces** — the third-party or internal integrations that the agent treats as reliable capability providers.

When Microsoft notes that malicious content may be linguistically obfuscated or embedded in seemingly benign files in ways that defeat simple keyword and regex filters, it is describing precisely the type of attack environment where autonomous systems are weakest and adversarial creativity is strongest (1). The attacker hides instructions not in executable code but in machine-interpretable context. If the agent can read it, reason over it, and act on it, the content becomes operational.

Why reasoning-layer compromise matters in enterprise intrusions

The strategic significance of this attack surface is that it collapses several steps of the intrusion chain. In a classical campaign, the attacker obtains access, executes code, establishes persistence, and later abuses privileges. In an agent-mediated environment, the attacker may instead inject content that causes the system to use its *existing privileges* in the attacker's interest. This is not a full substitute for traditional intrusion, but it can function as a high-value amplifier.

Microsoft states that depending on the system affected, these attacks may execute read or write commands, exfiltrate data, or subtly modify system behavior to suit attacker objectives (1). CrowdStrike extends the point by warning that the reasoning chain itself becomes the attack surface in agentic tool chain attacks (2). Combined, these observations show that enterprise defenders must now consider a new category of primary target environment: not merely the application or endpoint hosting AI, but the *semantic infrastructure* that determines how AI uses authority.

Primary agent surfaces under active pressure

AI agent surface	How adversaries influence it	Potential enterprise impact	Supporting source
Tool descriptions and usage examples	Poisoned or misleading semantic guidance	Wrong tool selection, unauthorized actions, hidden exfiltration	CrowdStrike tool chain attack analysis (2)
Retrieved context and external documents	Embedded prompt injection or obfuscated instructions	Data disclosure, behavioral hijack, workflow corruption	Microsoft prompt manipulation reporting (1)
MCP / A2A exchanges	Malicious tasking or adversarial context transfer	Cross-agent compromise propagation, delegated abuse	Microsoft notes exploitation via MCP and A2A (1)
Plugin / connector ecosystem	Trust abuse in external capability providers	Unauthorized system access, lateral movement via integrations	CrowdStrike notes manipulation of language, metadata, and context guiding tool use (2)
Agent memory and planning context	Persistence of adversarial instructions in state	Repeated unsafe actions despite benign user prompts	Inferred from continuous loop planning and context sensitivity described by CrowdStrike (2)

Embedded instruction channels as stealth infrastructure

One of the most consequential observations in Microsoft's generative AI threat map is the inclusion of **embedded prompt injection**, **sensitive information disclosure**, **data leak/exfiltration**, and **insecure plugin design** as central risk areas ([1](#)). This indicates that the primary attack surfaces are not isolated bugs but interconnected trust channels. An embedded prompt can alter tool choice; an insecure plugin can magnify the resulting action; the output may then disclose sensitive data or trigger downstream changes in another system.

For autonomous offensive operations, that means AI agents are attractive both as *targets* and as *proxies*. If compromised semantically, they can execute at machine speed using enterprise-approved

workflows. This is what makes them different from ordinary automation tools. A conventional script will do what it was coded to do. An agent will interpret. That interpretive layer is where the adversary now competes for control.

Endpoint-Resident Agents and LOTAIL: High-Permission Local Automation as an Intrusion Multiplier

This section is distinct from the earlier discussion of endpoint scripting and command interpreters. The previous report addressed shells and command runtimes as automatable interfaces in general. The present section examines a narrower and newer concern: the rise of **endpoint-resident AI agents** that combine local execution, system permissions, browser control, and file access in ways that create a qualitatively different attack surface. In short, the endpoint is no longer just a host to compromise; it is becoming a *platform for autonomous delegated action*.

CrowdStrike's recent reporting captures this shift through the concept of **living off the AI land (LOTAIL)**, which it characterizes as a new attack technique enabled by increasing agent autonomy, high system permissions, and minimal governance on endpoints (3). This framing is important because it parallels the older logic of "living off the land" abuse of legitimate binaries, but with a major difference: the abused native capability is now not just a binary or script host, but an intelligent agent capable of interpreting intent and chaining actions.

Why the endpoint is re-emerging as a strategic AI battleground

The endpoint has always been important because it is where users authenticate, create data, and exercise trust. What changes with personal and enterprise AI agents is that endpoints are accumulating *machine-operable authority*. CrowdStrike notes that code and computer-use agents, agentic browsers, and personal AI tools are being deployed especially on developer machines, and these systems can execute terminal commands, browse the web, interact with files, and take autonomous actions that may appear indistinguishable from legitimate user behavior (3).

This produces a highly favorable environment for adversarial machines. A compromised or manipulated local agent may already possess:

- access to active browser sessions,
- visibility into local files and cached documents,
- the ability to invoke command interpreters,
- access to development artifacts or SSH material,
- interaction rights with collaboration and cloud applications,
- and enough behavioral plausibility to blend with normal user workflows.

Unlike many server-side attack surfaces, the endpoint also contains rich context about business operations. Calendar items, file names, shell history, browser tabs, IDE state, and local notes can all inform adaptive decision-making. For a human attacker, turning that ambient context into action takes time and attention. For an AI-enabled operator, it can be ingested and operationalized far more quickly.

LOTAIL as a target-environment concept

LOTAIL should be understood not only as a tactic but as an indicator of *which endpoint environments matter most*. CrowdStrike identifies the dangerous convergence of **agent autonomy**, **high system permissions**, and **minimal governance** (3). Therefore, the highest-risk endpoint environments are those where one or more local AI agents can bridge user context and privileged action without rigorous mediation.

The following endpoint classes are especially exposed:

Endpoint environment	Why it is attractive to AI-enabled adversaries	Characteristic LOTAIL risk
Developer workstations	Rich in code, tokens, terminals, repositories, and cloud access	Autonomous file access, command execution, credential harvesting, package manipulation
Executive or finance user devices	High-trust communications and approval workflows	Business process fraud, data theft, meeting or email manipulation
Shared administrative jump hosts	Concentrated privileges and management utilities	Cloud and identity operations under valid administrative context
BYOD or lightly managed endpoints with AI assistants	Weak governance over local agents and plugins	Stealthy persistence in normal productivity tooling
Agentic browsers and computer-use agents	Can act directly on web applications and forms	Unauthorized SaaS actions under live user sessions

What is new here is that the endpoint agent can transform local context into cross-system action. A browser-based AI assistant can read a file, infer that it contains credentials or business value, open a web portal, upload or transmit data, and then continue interacting with another application—all

without malware in the traditional sense. The local AI capability becomes a bridge between otherwise distinct enterprise surfaces.

Blending with legitimate user behavior

CrowdStrike emphasizes that such autonomous endpoint actions can look **indistinguishable from legitimate user behavior traffic**, making them difficult for traditional tools to detect (3). This is a decisive point for CTI analysis because it affects not just detection but target selection. Adversaries prefer environments where the cost of stealth is low. Endpoint-resident agents reduce that cost because they reuse existing user channels: browsers, terminals, files, and approved applications.

This means that the most at-risk endpoint interfaces are not necessarily the most technically vulnerable. They are the ones where:

1. the AI agent can inherit user trust or session state,
2. the resulting actions resemble normal productivity behavior,
3. policy enforcement is fragmented across tools,
4. plugin or tool provenance is weak,
5. and telemetry does not preserve enough semantic context to distinguish user intent from agent-induced action.

When these conditions hold, an adversarial machine does not need custom persistence or exploitation sophistication. It can redirect local automation toward offensive ends.

OpenClaw and the broader super-agent problem

CrowdStrike's reporting on OpenClaw underscores the same risk from a product-neutral perspective: agentic AI systems can autonomously execute actions, call external tools, and chain operations together, while adversaries can manipulate them through **agentic tool chain attacks** or **AI tool poisoning** (4). This is notable because it shows that local agent risk is not confined to one implementation. The underlying exposure comes from architectural features common to many "super-agent" designs:

- autonomy,
- tool dependence,
- broad permissions,
- and environment-wide action chaining.

When these features converge on an endpoint, the machine becomes an attack broker inside the user’s own trust boundary. Even without explicit compromise of the underlying operating system, the agent can become a medium for exfiltration, action laundering, or lateral movement.

Endpoint-agent targets most relevant to offensive AI operations

The table below summarizes the specific endpoint-resident AI surfaces now emerging as primary targets.

Local AI surface	Adversarial objective	Why it matters operationally	Source support
Computer-use agents	Drive browser, UI, and file interactions autonomously	Enables cross-application tasking under user context	CrowdStrike LOTAIL discussion (3)
Code agents on developer endpoints	Access repositories, terminals, package workflows, local secrets	Facilitates software supply compromise and cloud access expansion	CrowdStrike notes deployment on developer machines with command and file capabilities (3)
Agentic browsers	Operate on SaaS applications via active sessions	Action laundering through normal web flows	CrowdStrike LOTAIL framing (3)
Tool/plugin ecosystem for local agents	Poison or manipulate capabilities the agent relies on	Converts local assistant into an attacker-controlled orchestrator	CrowdStrike OpenClaw analysis (4)
Local context stores and accessible files	Inject instructions or harvest sensitive content	Provides both steering input and exfiltration material	Consistent with Microsoft’s warning on malicious content embedded in benign files (1)

The strategic implication is clear: endpoint-resident agents turn the endpoint from a mere execution site into a *decision-capable operational surface*. That is why they must now be treated as primary target environments in the offensive AI landscape.

Cross-Surface Case Intelligence: What Current Field Reporting Reveals About the Most Attacked Environments

This final section does not repeat earlier case studies on AI-enabled personas, fake AI tools, or hosted model targeting. Instead, it synthesizes the specific field signals in the supplied reporting to identify which environments appear most pressured *right now* when viewed across identity, cloud, and agent surfaces.

Real-World Case Studies and Threat Intelligence on the Impact of Autonomous Cyber Capabilities on Attack-Defense Dynamics

Evidence Thresholds and Analytic Framing for “Autonomous Impact” in Live Intrusions

Because earlier sections already defined adversarial machines, described planning loops, and mapped actor categories, this section does **not** revisit architectural theory or adoption taxonomy. Instead, it isolates the narrower question of **how current field evidence shows autonomous or semi-autonomous capabilities changing attacker-defender interaction in practice**. The most important analytic distinction is between:

1. **autonomy as marketing rhetoric,**
2. **AI assistance embedded in a conventional campaign, and**
3. **operationally meaningful machine agency that changes tempo, scale, adaptation, or defender workload.**

For threat intelligence purposes, a case should be treated as materially relevant only if one or more of the following are observable:

- the machine element compresses the time between foothold and expansion;
- it materially increases target throughput or campaign parallelism;
- it adapts content, tooling, or sequencing after friction;
- it reduces the attacker’s dependence on specialist labor;
- it causes defenders to confront machine-generated variability rather than static tradecraft;
- or it shifts detection from malware artifacts toward behavioral or control-plane anomalies.

This evidentiary standard matters because the public ecosystem includes a mixture of direct observations, vendor hunting data, underground tool advertisements, and forward-looking

assessments. A mature CTI reading does not treat all of these as equivalent. Yet taken together, the latest reporting from 2025–2026 shows a converging pattern: even without fully autonomous “hands-free” intrusions, bounded machine autonomy is already altering attack-defense dynamics by shortening decision cycles, raising campaign concurrency, and eroding defender assumptions about human pacing. CrowdStrike’s 2026 Global Threat Report states that AI-enabled adversaries increased operations **89% year-over-year**, and that the average eCrime breakout time fell to **29 minutes**, with the fastest observed breakout in **27 seconds**—figures that, while not proving universal autonomy, strongly indicate that machine-accelerated stages are reshaping the operational window defenders must cover ([1](#)).

A useful way to frame current real-world impact is to distinguish **five operational effects** visible across recent reporting.

Operational effect	What changes in the field	Why it matters to defenders	Illustrative source signal
Tempo compression	Target research, lure generation, infrastructure testing, and post-compromise sequencing occur faster	Detection and human triage windows shrink sharply	CrowdStrike reports 29-minute average breakout, fastest 27 seconds in 2025 (1)
Volume amplification	More targets can be processed simultaneously with personalized content	Traditional controls are overwhelmed by scale plus realism	442% increase in vishing between H1 and H2 2024 tied to GenAI-driven social engineering (2)
Tradecraft democratization	Lower-skill actors can generate code, scripts, lures, and malware components	Entry barriers fall; niche expertise is less scarce	CrowdStrike notes lower-tier eCrime and hacktivists using AI to build scripts and malware such as Funklocker and SparkCat (3)
Surface expansion	AI systems, agent builders, and model-development platforms become direct intrusion terrain	Security scope expands beyond classic hosts, users, and apps	CrowdStrike observed threat actors exploiting tools used to build AI agents for unauthenticated access, persistence, credential

Operational effect	What changes in the field	Why it matters to defenders	Illustrative source signal
			harvesting, and malware deployment (3)
Adaptive evasion	Adversaries iterate payloads, prompts, and social engineering faster than rule updates	Static controls and signature-centric detections degrade faster	2026 reporting emphasizes AI weaponization across reconnaissance, credential theft, and evasion (1)

The CTI challenge, therefore, is not simply to ask whether a campaign is “fully autonomous.” The more operationally meaningful question is whether the machine component has altered the attacker’s **cost curve** or the defender’s **response burden**. The answer is now clearly yes in several classes of incidents.

First, machine assistance is reducing the amount of human preparation required before the first victim touchpoint. Social engineering no longer requires an operator to manually draft every lure, localize every message, or research every target from scratch. The result is not just more phishing or vishing—it is more **credible** phishing and vishing at materially larger scale. CrowdStrike’s 2025 findings that GenAI-driven social engineering coincided with a **442% increase in vishing** indicate that voice-centric fraud operations are benefiting from automation in content generation, role-play consistency, and pretext refinement (2). This matters because human defenders historically relied on the friction and inconsistency of manual scam operations; AI reduces both.

Second, autonomy is influencing what defenders experience **after initial access**. Earlier sections covered agentic planning mechanics in the abstract; the newer field evidence shows that machine-enabled attacks increasingly exploit environments where actions can be taken through legitimate interfaces rather than bespoke implants. That means defenders are pushed toward detecting “authorized” but malicious actions in SaaS, cloud, and AI development environments. CrowdStrike’s 2025 Threat Hunting Report explicitly notes exploitation of AI-agent-building tools for persistence, credential theft, and malware deployment, showing that the machine layer is no longer only an attacker aid but also a **victim environment** and a **pivot surface** (3).

Third, offensive AI is moving from a specialist or state-only capability toward a broader ecosystem in which lower-tier actors can operate with enhanced effectiveness. This is visible in reporting on GenAI-built malware becoming “already operational,” not theoretical, with early proof points such as Funklocker and SparkCat (3). The significance is not merely that AI can generate code. It is that it can reduce iteration time, help troubleshoot failures, and supply “good enough” offensive

components to actors who previously lacked development depth. Defender advantage has long depended partly on attacker skill scarcity; generative systems erode that scarcity.

Fourth, the public emergence of offensive AI platforms and malicious chatbots changes defender assumptions about the provenance of attack tooling. Dark Reading’s reporting on **Xanthorox AI** describes a modular, model-agnostic platform marketed as a one-stop offensive environment for cybercriminal operations (4). Earlier reporting on **FraudGPT** and **WormGPT** similarly showed that criminal ecosystems were already commercializing malicious AI-enabled assistance for phishing, fraud, and cybercrime workflows (5, 6). In CTI terms, these are important not because every advertised capability is real, but because they indicate an active supply chain for machine-augmented offense. Once tools are packaged, sold, and iterated in underground markets, their impact on attack-defense dynamics tends to outlast any single platform.

Finally, the defender burden is increasing not only because attackers move faster, but because defenders must validate a larger and noisier set of potential machine-mediated abuse cases. Fortinet’s 2026 CISO predictions emphasize prompt injection, data poisoning, model extraction, weak non-human identity controls, agent-to-agent trust issues, and AI-enabled deepfake fraud as business-relevant risks likely to intensify in 2026 (7). Even where some of these remain predictive rather than fully quantified, they show that the attack-defense balance is shifting at the level of **defensive scope**: enterprises now must secure not only endpoints, servers, and human identities, but also models, prompts, agents, orchestration layers, and machine identities.

A practical CTI grading model for autonomous-impact cases can therefore use the following scale:

Grade	Description	Typical evidence type	Defensive meaning
A	Direct, observed operational use with measurable impact	Incident response, hunting telemetry, validated vendor reporting	Immediate control and detection implications
B	Strong circumstantial evidence of embedded AI-enabled tradecraft	Campaign correlation, repeated vendor observations, underground tool usage tied to incidents	High-confidence planning assumption
C	Credible capability commercialization without full operational corroboration	Tool advertisements, leaked demos, researcher validation, partial sightings	Early warning; monitor for transition into operations

Grade	Description	Typical evidence type	Defensive meaning
D	Forward-looking expert prediction with limited direct field evidence	Industry outlooks, forecasts, tabletop-derived expectations	Strategic watch item, not yet primary evidence

Using that scale, the cases examined below mostly fall in the **A–C range**, with the strongest material impact visible in social engineering, AI-tool compromise, malware generation support, and operational tempo compression. The overall implication is that autonomous cyber capability is no longer best understood as a future singular event. It is better understood as a series of cumulative operational shifts that collectively narrow defender reaction time, increase attacker adaptability, and expand the number of systems that can serve either as offensive amplifiers or intrusion targets ([1](#), [2](#), [3](#)).

Field Case Cluster 1: AI-Scaled Social Engineering as a Machine-Speed Access Broker

This subsection is intentionally distinct from the earlier report section on “AI-supported social engineering at majority scale.” That earlier material focused on commercialization and ecosystem formation. The present section instead examines **how real-world AI-assisted social engineering changes attack-defense dynamics once deployed against enterprises**, especially in terms of conversion efficiency, response latency, and escalation pathways after the first user interaction.

Among all currently documented uses of adversarial AI, social engineering remains the clearest case in which machine assistance has crossed from novelty into high-consequence operational relevance. CrowdStrike’s 2025 Global Threat Report documented a **442% increase in vishing between H1 and H2 2024**, explicitly linking the surge to GenAI-driven social engineering and to the activity of eCrime actors including CURLY SPIDER, CHATTY SPIDER, and PLUMP SPIDER ([2](#)). That statistic is significant not simply because volume increased, but because vishing historically suffered from labor constraints: operators had to manage call scripts, adapt conversationally, maintain role consistency, and target victims with sufficient personalization. GenAI reduces the cognitive burden across all four dimensions.

The shift in dynamics can be understood through the attack chain.

Attack phase	Pre-AI or low-AI constraint	Machine-enabled change	Defender impact
Target research	Manual scraping and analyst review limited throughput	Fast synthesis of public, leaked, and contextual data into per-target profiles	Larger number of convincing, organization-specific approaches
Pretext generation	Human script writing created inconsistency and reuse artifacts	Dynamic generation of role-specific scripts, emails, and callback narratives	Harder user-side recognition of scams
Interaction support	Operator improvisation quality varied by skill and fatigue	Real-time script assistance and objection handling	Less reliable dependence on victim spotting verbal mistakes
Follow-on instruction	Human-run steps slowed execution	Immediate guidance for remote sessions, MFA prompts, app installs, or credential harvesting	Compression of time from contact to compromise
Campaign tuning	Human review slowed optimization	Rapid experimentation with wording, timing, and persona types	Defensive awareness campaigns age faster

The critical change is not that AI replaces the human caller in every case. Rather, it **augments the human enough to industrialize personalization**. This is what changes the defender’s position. Previously, one could assume a rough inverse relationship between scale and credibility: high-volume campaigns were generic, while highly tailored campaigns were expensive and limited. AI collapses that tradeoff.

CrowdStrike’s 2026 Global Threat Report strengthens this interpretation by reporting that AI-enabled adversaries increased operations by **89% year-over-year**, weaponizing AI across reconnaissance, credential theft, and evasion ([1](#)). Even if some campaigns remain partially human-driven, the operational result is that the human operator increasingly appears at the **point of leverage**—the final persuasion step—while AI handles preparatory and adaptive work around it. This is especially powerful in help-desk impersonation, IT troubleshooting scams, fake support workflows, and callback-based access theft.

Real-world impact on attack-defense balance appears in at least four ways.

1) Defender training decays faster.

Traditional anti-phishing education relies on recurring indicators: awkward language, generic salutations, timing anomalies, low-quality spoofing, or procedural deviations. GenAI degrades those indicators. Fortinet's 2026 analysis notes that organizations already saw a marked shift in phishing quality in 2024–2025, with AI producing highly targeted and well-constructed emails, and predicts a further rise in audio- and video-enabled deception in 2026 (7). If the quality floor rises, awareness training must address higher-fidelity deception, not merely “obvious scam” recognition.

2) Escalation from initial trust to operational foothold is faster.

Vishing campaigns often aim not merely at credential harvest but at **session establishment**: persuading users to approve MFA prompts, install remote support software, reset passwords, or enroll a new authenticator. Machine-assisted scripting means the adversary can tailor follow-on instructions based on user role, device type, or resistance pattern. This increases the chance that a social interaction becomes a live enterprise access event before detection teams are alerted.

3) The distinction between fraud and intrusion blurs.

Many organizations segregate anti-fraud, IAM, SOC, and help-desk workflows. AI-enabled social engineering exploits those seams. A vishing attempt that begins as “fraud” may produce an identity compromise that becomes a true enterprise intrusion. This blending is strategically important because defenders often have fragmented telemetry: voice events, ticketing anomalies, SaaS logins, and endpoint remote-tool installations may sit in different systems and different teams.

4) Access brokerage is becoming more machine-assisted.

The value of AI in social engineering is not only direct monetization through fraud, but its ability to act as an upstream feeder to credential theft, session hijacking, and initial-access brokering. A machine-assisted operation can process more employees, harvest more context, and pass better-qualified victims into later intrusion stages. This changes defender economics because the SOC must triage a larger denominator of plausible access anomalies generated from highly believable user interactions.

Dark Reading's coverage of malicious AI chatbots such as FraudGPT provides supporting context. John Bambenek's remark that such tools represented some of the first concrete incorporations of generative AI into attacker tooling rather than merely theoretical discussion is analytically important (5). From a CTI perspective, FraudGPT and WormGPT may be uneven in sophistication, but they mark the operational normalization of using generative systems as **interactive accomplices** for scam and intrusion preparation. Once criminal users become accustomed to conversationally

generating lures, scripts, and fraudulent content, the skill barrier for persuasive targeting falls materially.

The effect is even more severe when combined with deepfake-enabled voice or video deception. Fortinet anticipates a large increase in high-value BEC and related scams in 2026, citing the increasing triviality of generating convincing audio and visual impersonation (7). Although not every enterprise attack currently uses synthetic media, the attack-defense dynamic is already changing because defenders must now assume that **identity cues once reserved for trust reinforcement—voice, diction, executive phrasing, internal terminology—can be cheaply synthesized.**

A compact matrix of defensive implications is instructive.

Defender assumption	Legacy reliability	Reliability under AI-enabled social engineering	Consequence
Poor grammar signals phishing	Moderate	Low	User training based on textual quality becomes insufficient
Volume implies low personalization	Moderate to high	Low	Large campaigns can still appear bespoke
Voice contact provides authenticity	Moderate	Declining	Help-desk and executive impersonation become harder to disprove
Human scammers make more mistakes over time	Moderate	Lower	Real-time AI support sustains consistency
Security awareness content remains valid for months	Moderate	Low	Training and playbooks require more frequent refresh

The broader strategic result is that the **attacker no longer needs to choose between personalization and scale.** Defenders, however, must still validate each suspicious interaction individually. This asymmetry matters. It means that even partial autonomy in social engineering creates disproportionate defender burden because the cost of false negatives is high and the cost of investigating high-quality lures is nontrivial. CrowdStrike’s reported surge in AI-enabled operations

and vishing volume therefore represents more than a messaging trend; it is evidence that machine assistance is changing the practical throughput of initial access generation ([1](#), [2](#)).

Field Case Cluster 2: Compromise of AI Agent Toolchains and Development Platforms as an Offensive Force Multiplier

While previous reports covered AI-agent surfaces conceptually, this subsection is different in purpose: it focuses on **documented threat intelligence showing adversaries exploiting AI-building environments themselves**, and on how those intrusions alter the balance between attacker and defender. This is one of the most important 2025–2026 developments because it shows autonomous cyber capability affecting both sides of the equation simultaneously: attackers use AI to accelerate operations, and they also target enterprise AI infrastructure as a new source of privilege, code execution, and credential access.

CrowdStrike’s 2025 Threat Hunting Report provides one of the strongest available data points. It states that threat actors exploited vulnerabilities in tools used to build AI agents, obtaining **unauthenticated access**, establishing **persistence**, harvesting **credentials**, and deploying **malware and ransomware** ([3](#)). This is a highly consequential observation. It demonstrates that agentic systems are not merely external attacker aids; the ecosystems enterprises are building to deploy autonomous workflows are themselves emerging as privileged attack paths.

The attack-defense implications are distinctive because AI development and agent orchestration environments often combine characteristics that are rarely co-located elsewhere:

- high-value secrets,
- API connectivity to multiple business systems,
- broad plugin or tool execution permissions,
- accelerated deployment practices,
- immature logging or security baselines,
- and non-human identities with weak lifecycle governance.

When these environments are compromised, the attacker may gain not only local system access but also leverage over downstream tools, data stores, and workflow actions.

A case-oriented breakdown clarifies why these incidents are strategically different from ordinary application compromise.

Characteristic of AI-agent toolchain	Why attackers value it	Why defenders are disadvantaged
Centralized secrets for APIs, models, and services	One foothold can unlock multiple environments	Secret sprawl is poorly inventoried
Orchestration of autonomous actions	Attackers can redirect or hijack trusted workflows	Security reviews often lag development speed
Experimental plugins and connectors	Broad attack surface, inconsistent validation	Many controls assume stable enterprise software, not rapidly changing AI stacks
Non-human identities	Persistence can survive user resets and evade IAM assumptions	Ownership and rotation practices are immature
Blend of code, prompts, and web interfaces	Multiple control planes create many subtle abuse paths	Monitoring is fragmented across DevOps, AppSec, SOC, and data teams

CrowdStrike’s 2026 Global Threat Report adds a second strong signal by reporting malicious prompt injection into GenAI tools at **more than 90 organizations** and abuse of AI development platforms ([1](#)). This moves the issue beyond isolated weakness in one vendor’s product. It indicates that prompt-layer manipulation and AI platform abuse are recurring enterprise realities. In operational terms, prompt injection matters because it can transform trusted data flows into adversary-controlled instruction channels. The defender problem is subtle: the “payload” may not look like malware, exploit code, or even suspicious network traffic. It may appear as text content embedded in documents, websites, tickets, repositories, or other inputs consumed by a model or agent.

The attack-defense balance shifts here in three important ways.

1) **Compromise of AI infrastructure creates leverage disproportionate to initial effort.**

An attacker who compromises an AI-agent builder, orchestration platform, or model integration environment may inherit authenticated pathways into ticketing systems, code repositories, cloud resources, messaging platforms, or customer data systems. Traditional footholds often require stepwise lateral movement. AI workflow compromise can offer **pre-assembled lateral movement** because the enterprise has already connected the relevant systems for automation.

2) Detection becomes semantically harder.

Security controls are relatively mature for malware execution, suspicious parent-child processes, or impossible travel. They are less mature for detecting when an agent's behavior is malicious because the **instruction layer has been corrupted**. If an AI workflow legitimately reads emails, creates tickets, summarizes documents, queries data stores, and triggers automations, then malicious activity may appear as an aberrant sequence of otherwise allowed actions. This substantially raises the analytic burden.

3) Persistence may move into non-human identity and workflow state rather than implants.

Persistence in agentic environments can include API keys, service principals, workflow credentials, hidden prompt modifications, plugin registrations, or poisoned data sources. This is strategically important because eradication requires more than endpoint cleanup. The defender must understand machine identities, tool permissions, orchestration logic, and hidden context sources.

Fortinet's 2026 outlook reinforces this exposure by highlighting weak identity and authentication in agentic AI, the risks of agent-to-agent interactions, prompt injection, model extraction, and emergent vulnerabilities when autonomous services interact without strong security assumptions (7). Though framed partly as a prediction, these concerns align closely with CrowdStrike's operational reporting. The convergence suggests that the shift is not hypothetical: organizations are now running AI-enabled systems whose security models lag their privilege and connectivity.

One practical consequence is that AI development environments are increasingly attractive to adversaries **even when the AI function itself is not the final objective**. Attackers may target them for reasons familiar from classic intrusion tradecraft:

- secret theft,
- code execution,
- persistence,
- ransomware staging,
- privilege expansion,
- or data access.

What changes is the **density of privilege** in these environments. A single agent platform can hold the equivalent of access once distributed across several admins, service accounts, and integrations.

The following comparative table illustrates why defenders experience these intrusions differently from more traditional server breaches.

Dimension	Traditional application server compromise	AI-agent platform compromise
Initial goal	Execute code, steal data, pivot	Execute code, steal data, pivot, and hijack automation logic
Primary privilege source	Local credentials, app tokens	Local credentials plus orchestration secrets and tool permissions
Lateral movement style	Manual or scripted expansion	Expansion may occur through pre-authorized integrations
Persistence	Web shells, services, scheduled tasks, tokens	Tokens, agent configs, prompt state, connectors, non-human identities
Detection anchor	Processes, files, network beacons	Behavioral deviations in workflow execution and AI-mediated actions
Recovery complexity	Rebuild host, rotate creds, patch	Rebuild plus prompt/config review, secret rotation, connector audit, workflow validation

The presence of ransomware deployment in these environments, as noted by CrowdStrike, is especially important (3). It indicates that AI-agent infrastructure is not merely relevant to espionage or subtle data abuse; it can serve as a springboard for overt criminal monetization. In practical terms, this means the autonomous enterprise is creating not just new business workflows but also new **high-value choke points** for extortion.

A second-order change in attack-defense dynamics concerns trust. Organizations frequently accelerate AI adoption through cross-functional experimentation, often outside the mature governance pipelines applied to production identity infrastructure or financial systems. Attackers benefit from this asymmetry. The business urgency to ship AI workflows often exceeds the security team's capacity to model their abuse cases. Thus, autonomous capability changes the balance of power not only because attackers gain new tools, but because defenders are forced to secure **rapidly changing systems whose failure modes are not yet culturally internalized**.

The evidence base remains young, and one should avoid overstating the prevalence of fully autonomous compromise of AI stacks. However, the currently available field reporting is enough to establish three high-confidence CTI judgments:

1. tools used to build and operate AI agents are already being exploited in the wild (3);

2. prompt injection and abuse of enterprise GenAI systems are occurring across a meaningful organizational sample, not in isolated laboratory conditions ([1](#));
3. these compromises offer attackers unusually efficient access to credentials, persistence, and downstream automation paths, thereby increasing the disparity between attacker opportunity and defender visibility ([1](#), [3](#), [7](#)).

Field Case Cluster 3: GenAI-Assisted Malware Production, Code Adaptation, and the Erosion of Skill Barriers

This subsection differs from earlier content on commercialization and “GenAI-built malware becomes reality” by concentrating specifically on **what these developments mean for attack-defense dynamics in real operational environments**, rather than on market formation or actor categories. The key intelligence question is not whether AI can generate code—that is settled—but how code-generation assistance affects campaign survivability, adversary access to capability, and defender workload.

CrowdStrike’s 2025 Threat Hunting Report states that lower-tier eCrime and hacktivist actors are abusing AI to generate scripts, solve technical problems, and build malware, with **Funklocker** and **SparkCat** identified as early proof points that GenAI-built malware is already operational ([3](#)). This is one of the clearest signs that machine assistance is beginning to alter the composition of the threat field itself. Historically, sophisticated malware development required experienced operators, established malware families, or purchased services. With AI assistance, a broader range of actors can generate functional code fragments, wrappers, packers, loaders, or task-specific scripts.

The strategic importance lies less in perfect malware generation than in **iterative problem solving**. Generative systems can assist operators in:

- converting one language to another,
- drafting PowerShell, Python, shell, or VBA scripts,
- troubleshooting syntax and dependency errors,
- proposing evasion ideas,
- creating installers or decoys,
- modifying C2 routines,
- changing variable names and structural patterns,
- and rapidly rebuilding code after detection.

This changes defender burden because the attack surface of “possible malware” expands from known families and developer communities to a much broader universe of machine-assisted code variation.

Dark Reading’s 2026 prediction piece points to an AI arms race in which malware autonomy and code that “learns to fight back” become increasingly plausible, including concerns about self-learning agentic worms and malware that morphs tactics based on encountered defenses (8). Some of this remains predictive rather than fully evidenced in enterprise incident data. Yet the forecast is relevant because it identifies the path from current bounded automation to future autonomous malware behaviors. The present field evidence already shows the enabling conditions: cheap code generation, rapid iteration, and attackers willing to operationalize imperfect machine outputs.

To understand impact on attack-defense dynamics, it is helpful to distinguish **three levels of AI involvement in malware operations**.

Level	Description	Current evidence strength	Defender consequence
Code assistance	AI helps generate scripts, loaders, phishing kits, and troubleshooting advice	Strong	More actors can develop or customize tooling
Variant acceleration	AI supports frequent reworking of malware logic and obfuscation	Moderate to strong	Signature and static-analysis half-life declines
Autonomous adaptation	Malware changes behavior based on environment and defensive response with limited human intervention	Emerging/predictive	Detection must shift toward robust behavior and policy controls

The first level is already operationally significant. Threat actors no longer need deep coding ability to produce useful artifacts. Even if machine-generated code is noisy or imperfect, it can still support fraud, credential theft, commodity ransomware staging, data exfiltration scripts, or living-off-the-land wrappers. This matters because many enterprise incidents are not prevented by attackers lacking elegance; they are prevented by attackers lacking **functionality**. If AI supplies “good enough” functionality, more actors can cross the threshold into viable intrusion activity.

The second level—variant acceleration—may be even more consequential for defenders. AI can aid in frequent structural rewrites, helping operators make small but cumulatively significant changes to malware or scripts. The challenge for defenders is not merely one new sample; it is an **increased cadence of mutation**. If a payload can be altered repeatedly with minimal human effort, then

signatures, heuristics tuned to one variant, or reverse-engineering insights from yesterday’s sample lose value faster.

The third level—autonomous adaptation—remains less directly evidenced, but it is increasingly discussed in industry forecasts. Dark Reading warns of malware that could change tactics, processes, and techniques based on defenses encountered during attacks (8). Even if this exact form has not yet become common in the wild, defenders should note that the transition from “AI-generated code” to “AI-mediated runtime adaptation” is conceptually incremental, not categorical. Once malware can call local or remote models, interpret environmental feedback, and choose among branches, bounded autonomy becomes technically feasible.

Reporting on **WormGPT** and **FraudGPT** provides additional context for this progression. These tools were notable not because they represented fully self-operating attack systems, but because they normalized criminal acquisition of AI systems optimized for malicious use cases rather than constrained consumer safety settings (5, 6). As these ecosystems mature, the attacker need not build an in-house offensive LLM. They can instead subscribe to a capability layer that assists across code generation, social engineering, and campaign support.

For defenders, the net effect is a degradation of traditional assumptions about attacker segmentation.

Traditional assumption	Why it weakens under AI-assisted malware generation
High-quality tooling implies high-skill actor	AI can help lower-skill actors produce competent tooling
Malware development is a major bottleneck	Generative assistance reduces coding and debugging friction
Variant production is expensive	AI lowers the cost of rapid rewrites and repackaging
Commodity actors are easier to cluster	Machine-generated diversity can blur lineage and attribution cues
Static analysis produces enduring value	Useful half-life declines as variants mutate faster

There is also a subtle attribution problem. Machine-assisted coding can reduce stylistic consistency across malware families and operator outputs. If actors rely on AI for function generation, refactoring, and translation, the resulting code may contain fewer stable human fingerprints. This

does not eliminate attribution—operational infrastructure, victimology, timing, and objectives still matter—but it may weaken one class of technical signal.

Another effect is on **defensive prioritization**. Security teams have finite reverse-engineering and detection-engineering capacity. If AI-generated or AI-refactored malware increases the flood of unique samples, defenders may be pushed into triaging many low-to-medium-sophistication variants at the expense of deeper strategic hunting. Attackers benefit from this because volume itself becomes a denial mechanism against analyst attention.

The relationship between AI-assisted malware generation and attack tempo is also important. CrowdStrike's 2026 reporting that breakout time averaged **29 minutes** with a fastest observed breakout of **27 seconds** suggests that post-access action is increasingly compressed ([1](#)). Rapid code or script generation complements that compression. An operator who can request a tailored script on demand—or quickly rework one that failed—can sustain momentum during an intrusion. The defender is then dealing not only with fast movement, but with on-the-fly adjustment of tools as controls block earlier attempts.

A useful framing is that AI is changing malware from a mostly **pre-authored artifact problem** into a more fluid **interactive code supply problem**. That distinction matters operationally:

- In a pre-authored model, defenders can study families, map techniques, and deploy detections that remain useful over time.
- In an interactive supply model, each intrusion can generate bespoke or semi-bespoke code fragments, increasing analytic churn.
- Even when the generated code is unsophisticated, its novelty can be enough to bypass narrow or brittle controls.

The available evidence does not justify claiming that autonomous malware has broadly overtaken human-led operations. However, it does support several high-confidence judgments:

1. AI-assisted malware and script generation is already operational among lower-tier criminal actors ([3](#));
2. the main current impact is not superhuman sophistication, but lower skill barriers and faster iteration ([3](#), [5](#));
3. faster variant churn undermines static, signature-reliant, and family-centric defensive approaches;
4. forecasts of more autonomous malware behaviors in 2026 are credible enough to affect planning, because the enabling infrastructure is already in use ([8](#)).

Field Case Cluster 4: Autonomous Offensive Platforms, Underground Tooling, and the Transition from Human-Crafted Campaigns to Machine-Orchestrated Offense

Earlier sections examined commercialization patterns in general. This subsection is narrower and distinct: it assesses **what the emergence of offensive AI platforms and malicious AI tooling means for defender strategy once these systems become accessible as reusable operational infrastructure**. The key shift is from isolated actor experimentation to a broader transition in which machine-orchestrated offense becomes purchasable, modular, and reusable.

Dark Reading's April 2025 reporting on **Xanthorox AI** described it as a modular, model-agnostic GenAI platform for offensive cyberattacks and a one-stop shop for developing a range of cybercriminal operations (4). Whether every advertised feature was mature is less important than the underlying market signal: threat actors are attempting to package offensive AI into workflow-centric platforms rather than one-off scripts or narrow assistants. In criminal ecosystems, packaging changes everything. Once a capability becomes a product, users no longer need to understand its internals to derive value from it.

The emergence of such platforms alters attack-defense dynamics in several ways.

1) Offensive capability becomes composable.

A modular offensive platform can combine reconnaissance support, phishing content generation, persona development, malware drafting,

Conclusion

The research shows that “adversarial machines” are no longer a theoretical concept or just another label for attacker automation; they are best understood as machine-mediated systems that can perceive conditions, choose among options, and adapt multi-step attack chains with limited human supervision. In practice, most offensive use in 2025–2026 remains bounded and hybrid rather than fully autonomous, but that is already enough to change campaign economics. Threat actors are embedding AI into reconnaissance, phishing, credential and session theft, cloud and identity path discovery, malware refactoring, infrastructure rotation, and post-compromise decision loops. The most active adopters appear to be state espionage ecosystems, state-aligned proxy and influence actors, ransomware and extortion groups, initial access brokers, and emerging offensive service providers, all of whom benefit from narrower forms of autonomy that reduce labor, increase speed, and improve adaptation under defender pressure. The environments most exposed are identity systems, cloud and SaaS control planes, enterprise management surfaces, browsers, developer and

CI/CD ecosystems, AI-agent toolchains, and endpoint-resident agents—because these are highly instrumented, API-accessible, and rich in machine-readable trust relationships rather than requiring bespoke malware at every step. ([Microsoft, 2026](#); [Google Threat Intelligence Group, 2026](#); [NIST, 2025](#))

The most important finding is that autonomous cyber capability is already shifting the balance of power by compressing attacker decision cycles and forcing defenders to respond to adaptive, machine-speed tradecraft rather than static tools. Real-world reporting points to AI-scaled social engineering, runtime code and command generation, exploitation of AI development and agent-building platforms, and commercialization of malicious AI assistants and offensive wrappers as the clearest signs of impact. CrowdStrike’s reporting on sharply reduced breakout times, large increases in AI-enabled operations and vishing, and exploitation of AI-agent tooling, along with Mandiant’s observations of malware querying LLMs in live operations and ENISA’s documentation of stand-alone malicious AI systems and fake AI-tool ecosystems, all indicate that the immediate threat is not a cinematic “fully autonomous hacker” but a growing set of reusable machine-controlled modules that make attackers faster, more scalable, and harder to disrupt with indicator-based defenses alone. The implication for enterprises is clear: security programs must shift from malware-centric detection toward identity, token, API, workflow, and semantic-behavior monitoring; harden non-human identities and delegated trust paths; govern agentic systems and toolchains as privileged infrastructure; and prepare for an offensive landscape in which AI lowers attacker skill barriers while expanding the number of surfaces that can be abused or hijacked. ([CrowdStrike, 2026](#); [Mandiant, 2026](#); [ENISA, 2025](#))

References

- <https://darkreading.com/cyber-risk/cybersecurity-predictions-2026-an-ai-arms-race-and-malware-autonomy>
- <https://ir.crowdstrike.com/news-releases/news-release-details/2025-crowdstrike-global-threat-report-chinas-cyber-espionage/>
- <https://thehackernews.com/2023/02/newspenguin-threat-actor-emerges-with.html>
- <https://thehackernews.com/2023/10/gaza-linked-cyber-threat-actor-targets.html>
- <https://www.crowdstrike.com/en-us/press-releases/2026-crowdstrike-global-threat-report>
- <https://thehackernews.com/2022/06/researchers-warn-of-matanbuchus-malware.html>
- <https://thehackernews.com/2022/04/multiple-hacker-groups-capitalizing-on.html>
- <https://www.csoononline.com/article/1307613/nation-state-threat-actors-using-llms-to-boost-cyber-operations.html>
- <https://www.darkreading.com/cloud-security/sans-top5-cyber-broken-out-soc>
- <https://thehackernews.com/2023/08/syrian-threat-actor-evlf-unmasked-as.html>

- <https://marketingassets.microsoft.com/gdc/gdcZfcOcj/original>
- <https://csoonline.com/article/4008912/wormgpt-returns-new-malicious-ai-variants-built-on-grok-and-mixtral-uncovered.html>
- <https://www.crowdstrike.com/wp-content/uploads/2020/08/crowdstrike-dragos-ics-ot-data-sheet.pdf>
- <https://www.microsoft.com/security/blog/2019/12/17/norsk-hydro-ransomware-attack-transparency>
- <https://thehackernews.com/2023/09/ukraines-cert-thwarts-apt28s.html?m=1>
- <https://marketplace.crowdstrike.com/listings/acalvio-advanced-threat-defense>
- <https://www.darkreading.com/threat-intelligence/autonomous-genai-attacker-platform-chat>
- <https://www.crowdstrike.com/content/crowdstrike-www/locale-sites/us/en-us/press-releases/crowdstrike-releases-2025-threat-hunting-report.html>
- <https://thehackernews.com/2024/08/vietnamese-human-rights-group-targeted.html?m=1>
- <https://thehackernews.com/2022/08/new-grandoreiro-banking-malware.html>
- <https://www.darkreading.com/threat-intelligence/fraudgpt-malicious-chatbot-for-sale-dark-web>
- <https://www.crowdstrike.com/resources/reports/threat-hunting-report>
- <https://darkreading.com/ics-ot-security/armis-acquires-otorio-expand-ot-exposure-management-platform>
- <https://thehackernews.com/2023/07/wormgpt-new-ai-tool-allows.html>
- <https://thehackernews.com/2024/08/vietnamese-human-rights-group-targeted.html>
- https://www.darkreading.com/threat-intelligence?utm_activation=corporate%2Bblog&page=48
- <https://www.crowdstrike.com/en-us/press-releases/crowdstrike-releases-2025-threat-hunting-report>
- <https://thehackernews.com/2023/07/new-ai-tool-fraudgpt-emerges-tailored.html>
- <https://ir.crowdstrike.com/news-releases/news-release-details/2025-crowdstrike-threat-hunting-report-adversaries-weaponize-and>
- <https://thehackernews.com/2023/04/kubernetes-rbac-exploited-in-large.html>
- <https://cloud.google.com/blog/topics/threat-intelligence/gestalt-mitre-attack-ics>
- <https://www.darkreading.com/cloud-security/detecting-cloud-threats-with-cloudgrappler>
- <https://www.fortinet.com/uk/blog/ciso-collective/ciso-predictions-for-2026>
- <https://thehackernews.com/2023/04/daggerfly-cyberattack-campaign-hits.html>
- <https://thehackernews.com/2024/04/massive-phishing-campaign-strikes-latin.html>
- [https://ctid.mitre.org/resources/2024-impact-report/2024 Impact Report Center for Threat-Informed Defense.pdf](https://ctid.mitre.org/resources/2024-impact-report/2024%20Impact%20Report%20Center%20for%20Threat%20Informed%20Defense.pdf)

- <https://www.darkreading.com/cyber-risk/dhs-warns-of-cyberattack-on-natural-gas-pipeline-companies>
- <https://ics-cert.kaspersky.com/publications/reports/2024/01/31/ics-and-ot-threat-predictions-for-2024>
- <https://www.crowdstrike.com/en-us/blog/ransomware-actors-evolved-operations-in-2020>
- <https://www.darkreading.com/threat-intelligence/new-malware-campaign-targets-job-seekers>
- <https://www.csoonline.com/article/4008912/wormgpt-returns-new-malicious-ai-variants-built-on-grok-and-mixtral-uncovered.html>
- <https://thehackernews.com/2023/07/jumpcloud-blames-sophisticated-nation.html>
- <https://thehackernews.com/2023/07/wormgpt-new-ai-tool-allows.html?m=1>
- <https://thehackernews.com/2023/04/new-qbot-banking-trojan-campaign.html>
- <https://www.crowdstrike.com/de-de/blog/ransomware-actors-evolved-operations-in-2020>
- <https://www.darkreading.com/mobile/actzero-teams-up-with-uscellular-to-secure-mobile-devices-from-ransomware-attacks>
- <https://thehackernews.com/2026/02/google-ties-suspected-russian-actor-to.html>
- <https://www.microsoft.com/en-us/security/blog/2026/03/19/when-tax-season-becomes-cyberattack-season-phishing-and-malware-campaigns-using-tax-related-lures>
- <https://www.darkreading.com/vulnerabilities-threats/cyber-defenders-lead-the-ai-arms-race>
- <https://www.crowdstrike.com/en-us/press-releases/crowdstrike-releases-2025-global-threat-report/>
- <https://ctid.mitre.org/resources/2024-impact-report/2024%20Impact%20Report%20Center%20for%20Threat-Informed%20Defense.pdf>
- <https://www.csoonline.com/article/4143393/the-insider-threat-rises-again.html>
- <https://www.csoonline.com/security>
- <https://www.darkreading.com/cyber-risk/ai-gives-defenders-the-advantage-in-enterprise-defense>
- <https://www.crowdstrike.com/content/dam/crowdstrike/www/en-us/wp/2020/08/dragos-ics-ot-threat-detection-solution-brief.pdf>
- <https://www.microsoft.com/en-us/security/blog/2025/07/31/modernize-your-identity-defense-with-microsoft-identity-threat-detection-and-response/>
- <https://thehackernews.com/2023/02/financially-motivated-threat-actor.html>
- <https://www.crowdstrike.com/en-us/blog/cross-domain-defense-with-intel-led-threat-hunting/>
- <https://www.darkreading.com/ics-ot-security/armis-acquires-otorio-expand-ot-exposure-management-platform>
- <https://thehackernews.com/2025/04/woocommerce-users-targeted-by-fake.html>
- <https://marketplace.crowdstrike.com/listings/dragos-ics-ot-threat-detection/>

- <https://www.mitre.org/sites/default/files/2025-04/PR-24-01820-29-MITRE-Response-OSTP-RFI-AI-Action-Plan.pdf>
- <https://www.cyberdefensemagazine.com/ai-on-the-frontlines-how-agentic-ai-is-revolutionizing-cyber-defense/>